加雲聯網股份有限公司

Secure Project/System Security Management Guideline – Annexes

整合/維護專案和系統安全管理指南-附件

版 別：1.0

制訂日期：2024 年 2 月 2 日

修訂日期：2024 年 2 月 2 日

制修部門：稽核室

頁 數：X

核准	審查	制定

文件發行/修訂記錄

版次	發行日期	生效日期	制修內容摘要
1.0			

Content

Annexes A: Practice Examples for Security Implementation 4
A.1 Security Management Plan (Example) 4
A.2 Security Vendor Management Plan (Example) 4
A.3 SI/SM Project Security Management Plan (Example) 5
A.4 Security Policies and Procedures Plan (Example) 6
A.5 Data Flow Diagram (Example) 9
A.6 Inventory Asset List (Example) 11
A.7 Simple Network Diagram (Example) 12
A.8 Threat and Risk Assessment Report (Example) 14
A.9 Security Functional Description Specifications (Example) 16
A.10 IACS Automation Solutions/Asset Hardening Recommended Practices (Example) 21
A.11 OT Security Inspection and Test Protocol (FAT/SAT Test Case) (Example) 21
A.12 OT Security Vulnerability Scanning Report & Results (Example) 22
Annexes B: Annexes Related to the Security Policy and Procedure 24
B.1 Key Competencies of Roles for the Project/System or the Project 24
B.2 Organizational Independence for the Project Security Assurance Organization 29
B.3 The Proforma Form for Verifying File Integrity 34
B.4 The corresponding Security program process and guidelines 36
Annexes C: Security Verification Checklist for Security Implementation 49
C.1 The Security Plan Checklist 49
C.2 Threat and Preliminary Risk Assessment (TRA) Verification Checklist 55
C.3 Network Architecture Documentation Verification Checklist 57
C.4 Inventory Asset List Verification Checklist 59
C.5 Critical Security Design Verification Checklist 60
C.6 Documents of System Security Countermeasures Verification Checklist 64
C.7 System Security Acceptance Testing Verification Checklist 121
C.8 Operation and Support/Maintenance Verification Checklist 125

Annexes A: Practice Examples for Security Implementation

A.1 Security Management Plan (Example)

Preface: The purpose of this document is to document a Project/System Security Management Plan.

TABLE OF CONTENTS

1 Purpose
  (1). Introduction
  (2). Purposes and Objectives
2 Scope of application
3 Definitions
4 Project Assets and Suc Description
  Description and scope of the system under consideration (SuC)
5 Cybersecurity Documentation
  Description of the expected document output, and the protection of the confidentiality of the PE/O's data
6 Documentation of Policies and Procedures for Protecting the Assets
7 Cybersecurity Governance
  Description of the source of the requirements.
8 Project Role & Responsibility
9 Timeline Of Implementation and Personnel Dedication
10 Organization Controls Planning for Gates
11 Testing Cases and Programs for Systems
12 Permit to Work (PtW) processes

A.2 Security Vendor Management Plan (Example)

Preface: The purpose of this document is to document a Project/System Security Vendor Management Plan.

TABLE OF CONTENTS

1 Purpose
  (1). Introduction
  (2). Purposes and Objectives
2 Scope of application
3 Definitions
4 Project Assets and Suc Description
5 Governance/Strategy
  5.1 Main Contractor responsibilities
  5.2 Vendors responsibilities
  5.3 Asset responsibilities
6 Communicate Requirements to Vendor
  6.1 Vendor selection process
  6.2 Engineering plan
7 Vendor Management after Purchase Order

7.1 Progress follow-up
7.2 Vendor tests management
7.2.1 Inspection and Test Protocol (ITP)
7.2.2 FAT
7.2.3 SAT
8 Permit to Work (PtW) processes of PE/O
9 Appendix Template of Security Background Document

A.3 SI/SM Project Security Management Plan (Example)

Preface: The purpose of this document is to document a SI/SM Project Security Management Plan.

TABLE OF CONTENTS

1 1.0 目的 Object
1.1 1.1 簡介 Introduction
1.2 1.2 本文件的目的和目標 Purposes and Objectives of This Document
2 2.0 適用範圍 Scope
2.1 2.1 本文件範圍 Scope of This Document
2.2 2.2 本指南的適用性和有效性 Applicability and Validity of This Guide
a 2.2.1 適用性 Applicability
b 2.2.2 有效性 Validity
3 3.0 責任 3.0 Responsibility
4 4.0 名詞定義 4.0 Definitions
5 5.0 作業說明 Instructions
5.1 5.1 安全系統整合/維護服務專案概述 Secure SI/SM Project Overview
a 5.1.1 專案概述 Project Overview
b 5.1.2 系統或 IACS 自動化解決方案概述 System or IACS Automation Solution Overview
5.2 5.2 安全政策與管理理念 Security Policy and Management Philosophy
a 5.2.1 安全政策 Security Policy
b 5.2.2 安全管理理念 Security Management Philosophy
5.3 5.3 安全保證組織 Security Assurance Organization
a 5.3.1 專案安全保證組織 Project Security Assurance Organization
b 5.3.2 角色與責任 Roles and Responsibility
c 5.3.3 能力要求 Competency Requirements
(a) 5.3.3.1 安全背景調查 Security-Related Background Checks
d 5.3.4 其他相關計畫的介面管理 Management of Interfaces with Other Relevant Programs, include Permit to Work (PtW) processes.
5.4 5.4 安全績效目標與要求 Security Performance Targets and Requirements
a 5.4.1 風險分類矩陣 Risk Classification Matrix
b 5.4.2 安全目標 Security Targets
c 5.4.3 最低合理可行原則 ALARP Principle
d 5.4.4 安全要求 Security Requirements
5.5 5.5 安全計畫和任務 Security Program and Activities

a 5.5.1 安全整合/維護服務專案生命週期 Secure SI/SM Project Lifecycle
b 5.5.2 專案安全任務和/或活動 Project Security Tasks and/or Activities
c 5.5.3 專案安全保證產出文件和時間表 Project Security Assurance Deliverables and Schedule
d 5.5.4 服務水準協議/協定 Service Level Agreement (SLA) Protocol

5.6 5.6安全保證方法 Secure Assurance Approach
a 5.6.1 一般原則 General Principles
b 5.6.2 安全基線要求和控制措施 Baseline Security Requirements and Control Measures
c 5.6.3 安全保證流程 Security Assurance Processes
d 5.6.4 安全研討 Security Studies
e 5.6.5 網宇威脅和漏洞日誌 Cyber Threats and Vulnerability Log
f 5.6.6 安全關鍵要素、要求和清單 Security Critical Elements, Requirements, and List
g 5.6.7 網宇威脅管理系統 Cyber Threats Management System

5.7 5.7安全保證管理 Security Assurance Management
a 5.7.1 品質管理 Quality Management, include Management of Change (MOC).
b 5.7.2 安全管理 Security Management
c 5.7.3 安全審查、稽核和評鑑 Security Reviews, Audits, and Assessment

5.8 5.8使用表單 Proforma Table Use：

6 6.0 附件 Appendix

A.4 Security Policies and Procedures Plan (Example)

Preface: The purpose of this document is to document a Project/System.

TABLE OF CONTENTS

1 Purpose
(1). Introduction
(2). Purposes and Objectives
2 Scope of application
3 Definitions
4 Account Management Policy
4.1 Account
a Centralized Accounts
(Documented process to select account management application(s) satisfying points 1) to 4) of the requirement (e.g. LDAP product))
(Documented process to select unique user accounts for each user of an automation solution)
(Documented process of selection of related account management application(s))
b Local accounts
c User Identity Validity
d Account Naming
4.2 Documentation Of Policies and Procedures for Protecting the Assets

a Rights Principles
a Authorization Levels
b Rights Matrix (Roles and Permissions)
c Exception
4.3 Password Policy
a General user account password policy
b Local Administrator user account password policy
c Operational and System Administrator user account password policy
5 Vulnerability Management procedure
5.1 Process steps Description
a Vulnerability Management Report Map
b Vulnerability Management Process
c Security Analysis Tool Evaluation
5.2 Logical Structure of the vulnerability solution
a Test Configuration
b Test Method/Tool
5.3 Vulnerability handling process
6 Backup/Restore procedure
6.1 Backups
a Backup of assets and information
b Backup Supervision
• Windows based host servers
• ICS Devices
• Network Devices
6.2 Backup Security
a Retention and Frequency
6.3 Restoration
a Testing Request
b Testing Exercise
6.4 Disaster Scenarios
a Windows based host server crash in SCS environment
b Malware detected during backup
c Corrupt configuration file
6.5 Recovery Procedures
a Windows based host servers Recovery
b ICS and Network Devices Recovery
6.6 Logical setup of the backup infrastructure
6.7 Appendix backup and restore procedures
a Backup and Recovery of Windows based host servers
7 Systems Malware Protection procedure
7.1 General Rules
7.2 CENTRAL Management
a Malware Protection for on-site host computers
b Malware Protection for computers that temporarily connected to the on-site

network or devices
c Malware Protection for portable medias
7.3 UPDATE & PATCH
a Logical structure of Malware Protection for on-site host computers
b Logical structure of Malware Protection for computers that temporarily connected to the on-site network or devices
c Logical structure of Malware Protection for portable medias
7.4 INCIDENT MANAGEMENT
7.5 Device with no protection mechanisms
7.6 Logical structure of Malware protection
a Logical structure of Malware Protection for on-site host computers
b Logical structure of Malware Protection for computers that temporarily connected to the on-site network or devices
c Logical structure of Malware Protection for portable medias
8 Change and Patch Management procedure
8.1 Main Principles of Configuration
8.2 Windows based host servers (WBHS)
a WBHS Configuration Files (tentative)
b WBHS Configuration Revision Control & Management Table (tentative)
8.3 ICS & Network Devices Configuration
a ICS & Network Devices Configuration Files (tentative)
b ICS & Network Devices Configuration Revision Control & Management Table (tentative)
8.4 Change Management
8.5 Patch Management
a Patch Management Map
b Patch Management Process
9 Logging, monitoring, and reporting procedure
9.1 Information Logging
a Overview of information logging policy
b Purpose of information logging policy
c Scope of information logging policy
d Information logging policy standard
e Information logging policy compliance
9.2 Asset Monitoring
a Overview of asset monitoring policy
b Purpose of asset monitoring policy
c Scope of asset monitoring policy
d Asset monitoring policy standard
e Asset monitoring policy compliance
9.3 Event Management & Reporting
a Security Log Management Goals
b Logging General Setup
c Collected Data Quality

d Data Security and Integrity
e Event From the Devices (tentative)

9.4 Storing and forwarding of the event
a Storing process.
b Access
c Forwarding

9.5 Logical logging Setup

A.5 Data Flow Diagram (Example)

Preface: The purpose of this document is to document a Project/System Data Flow Diagram.

TABLE OF CONTENTS

1 Introduction
(1). Purposes and Objectives
(2). Scope of application
(3). Glossary of Term and Definitions
(4). Applicable Documents
2 Project Assets and SuC Description (Example diagrams)
(1). SuC Description
(2). The initial assets of the SuC
3 ILRA updated Network Diagram
4 SuC dataflow diagram (Example diagrams)
4.1 A-1 Subsystem

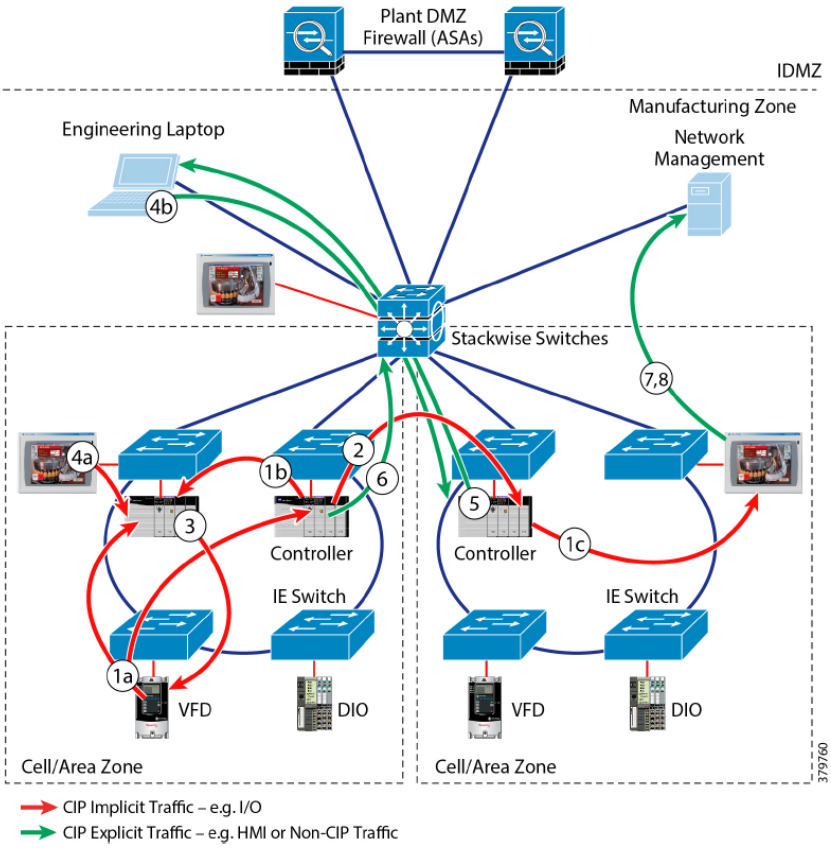


Figure 1 the possible data flow direction

Information Notes:

(1). Each data flow should be described or drawn in the following rules:

(2). Function description of each host

(3). Interfaces, ports of devices

(4). Each data flow direction is only one-way

(5). Protocols of each data flow direction

(6). Short function description for each data flow direction

service protocols：

Refer Number in Figure	From	To	Description	Protocol	Type	Port
1 a,b,c	Producer (for example, VFD Drive)	Consumer (for example, controller)	A producer (for example, VFD Drive, or controller) communicates data via CIP Implicit I/O (UDP multicast) traffic to multiple consumers a—Represents device to controller IO b—Represents controller–controller I/O c–Represents controller reporting real-time status to HMI	EtherNet/IP	UDP	2222
2	Producer	Consumer	Producers can communicate data via CIP I/O as UDP unicast traffic to a consumer.	EtherNet/IP	UDP	2222

A.6 Inventory Asset List (Example)

Preface: The purpose of this document is to document a Project/System Inventory Asset List.

TABLE OF CONTENTS

1 Purpose
- (1). Introduction
- (2). Purposes and Objectives

2 Scope of application

3 Definitions

4 Basic Sheet
- (1). Device Name-ID
- (2). Device Description-Purpose
- (3). Device Category
- (4). Device SL-T
- (5). Zone
- (6). Plant Area Association
- (7). Physical Location
- (8). Connection
- (9). Permanent /Temporary
- (10). Manufacturer Name
- (11). Manufacturer Model #
- (12). Real Time Operating System (OS)
- (13). Bios/Firmware
- (14). Notes

5 Security Sheet for Risk Assessment
- (1). Unique identifier
- (2). Name
- (3). Model/version
- (4). Supplier/Contractor/Fabricator
- (5). Services running
- (6). Software and applications
- (7). Patch status
- (8). Anti-virus status
- (9). IP & MAC addresses
- (10). Network segment
- (11). Hypervisors
- (12). OS/Firmware version
- (13). Security software installed (type and version)
- (14). Open Ports
- (15). Protocols

6 Optional Sheet
- (1). RDS-PP- Reference Designation System for Power Plants
- (2). Asset description/role
- (3). Logical location. Reference to location in the Simple Network Diagram Physical

location

(4). Data flows

(5). Conduit enforcing the policies

(6). Backup status

(7). Logging storage capabilities (size)

(8). Criticality

(9). Risk profile

(10). Responsible person/role

(11). Contact details

A.7 Simple Network Diagram (Example)

Preface: The purpose of this document is to document a Project/System Simple Network Diagram.

TABLE OF CONTENTS

1 Purpose

(1). Purposes and Objectives

(2). Scope of application

(3). Glossary of Term and Definitions

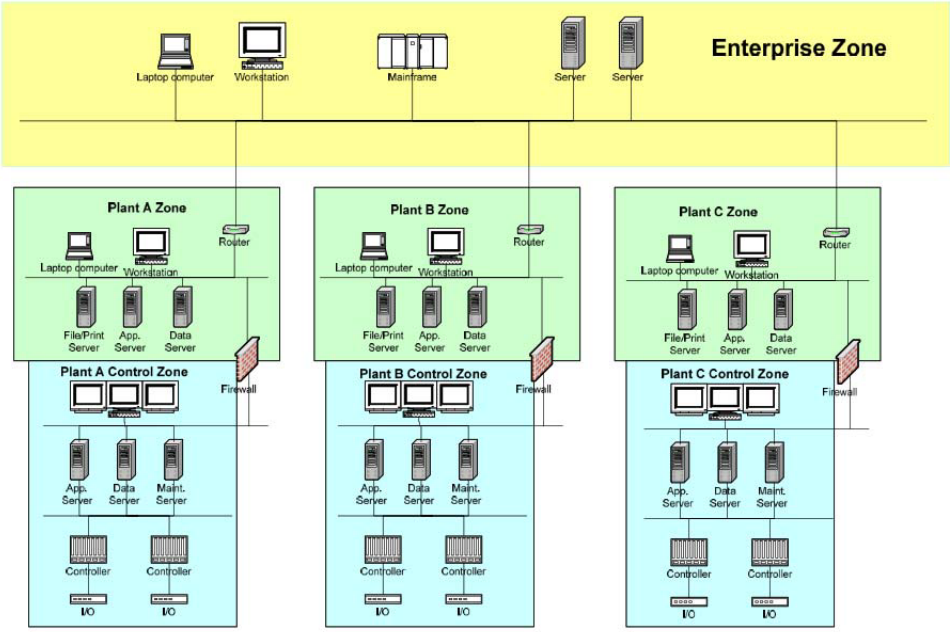
(4). Applicable Documents

2 Project Assets and SuC Description (Example diagrams)

(1). SuC Description

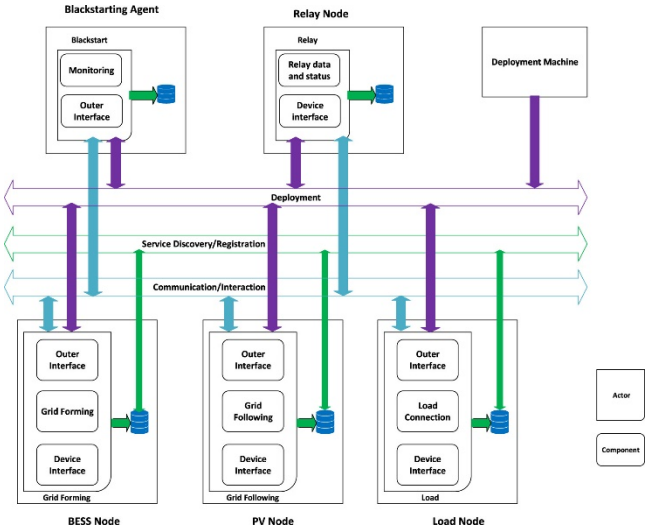
(2). The initial assets of the SuC

3 SuC network diagram



(Source IEC 62443-1-1)

(1). SuC simply network flow diagram (Systemise)


Blackstarting Agent
Blackstart
Monitoring
Outer Interface
Relay Node
Relay
Relay data and status
Device Interface
Deployment Machine
Deployment
Service Discovery/Registration
Communication/Interaction
Outer Interface
Grid Forming
Device Interface
Grid Forming
BESS Node
Outer Interface
Grid Following
Device Interface
Grid Following
PV Node
Outer Interface
Load Connection
Device Interface
Load
Load Node
Actor
Component

A.8 Threat and Risk Assessment Report (Example)

(It will be a deliverable to the asset owner)

Preface: The purpose of this document is to document a Project/System Threat and Risk Assessment Report.

TABLE OF CONTENTS

1 Introduction
- (1). Purpose and Objectives
- (2). Scope of application
- (3). Glossary of Term and Definitions
- (4). Applicable Documents

2 Security Context
- (1). SuC Description
- (2). The assets of the SuC
- (3). Preliminary network architecture
- (4). Safeguarding Requirements of Data Storage Points/Document and Dataflows Identification
- (5). Data Flow Diagram (DFD)
- (6). Possible Threats
  - a Description of the Threat Source
  - b Possible Threat Events
- (7). Potential Impact to the Environment
  - a The possible sequence of attacks and impacts
  - b Unmitigated risks, security measures, and residual risks

3 Security Profile
- (1). The Proforma Form for Conducting the High-Level Cybersecurity Risk Assessment (HLCRA) results

Threat-Vulnerability ID	Zone	Conduit	Asset ID	Description	Threats Description	Vulnerability Description	Attack Methods and Scenarios Description	Unwanted Incidents Description	Consequences	Proposed Security Measures/Control Measures/Countermeasures						DRAR Required?	Remarks
										Equipment/Device Security	Data Protection	System Administration	Application Security	Network Security	Advanced Mitigation Strategies		

- (2). The Proforma Form for Conducting the Detailed Risk Assessment Requirements (DRAR)

Threat-Vulnerability ID	Zone	Conduit	Asset ID	Description	Threats Description	Vulnerability Description	Attack Methods and Scenarios	Unwanted Incidents Description	Consequences	Attack Potential (AP)						Damage Potential (DP)					Unmitigated Risk			Required SL-T		Proposed Security Measures/Control Measures/Countermeasures					Attack Potential (AP)						Damage Potential (DP)					Mitigated Risk			Achieved SL		Risk Tolerable or Acceptable?	Remarks
										Time to perform an attack	Expertise	Knowledge	Opportunity	Equipment	AP Value	Likelihood Level	Safety	Finance	Operational Functionality	DP Value	Impact Category	Risk Value	Risk Level	Risk Category	CRRF	SL-T	Equipment/Device Security	Data Protection	System Administration	Application Security	Network Security	Advanced Mitigation Strategies	Time to perform an attack	Expertise	Knowledge	Opportunity	Equipment	AP Value	Likelihood Level	Safety	Finance	Operational Functionality	DP Value	Impact Category	Risk Value	Risk Level	Risk Category	CRRF	SL-A		

(3). Analysis Tools and Results

A brief introduction of the analysis tools used as well as the conclusion and discussion of the analysis results should be described in a security risk assessment report when appropriate.

The security risk assessment results and the proposed security measures and/or countermeasures for a threat modelling can be documented in Table A.1 and Table A.2 given below. Table A.1 and Table A.2 can be also used for the security risk register of a Product/System and/or a Third-Party Component (TPC).

Table A.1 The Proforma Form for Conducting the Security Profile (with an Example).

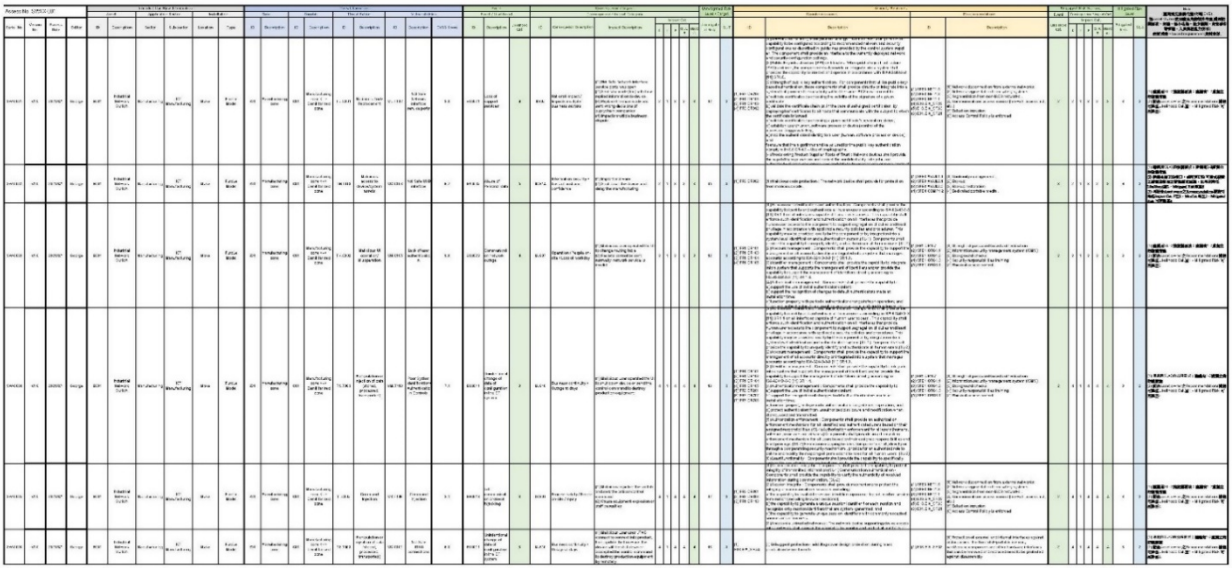
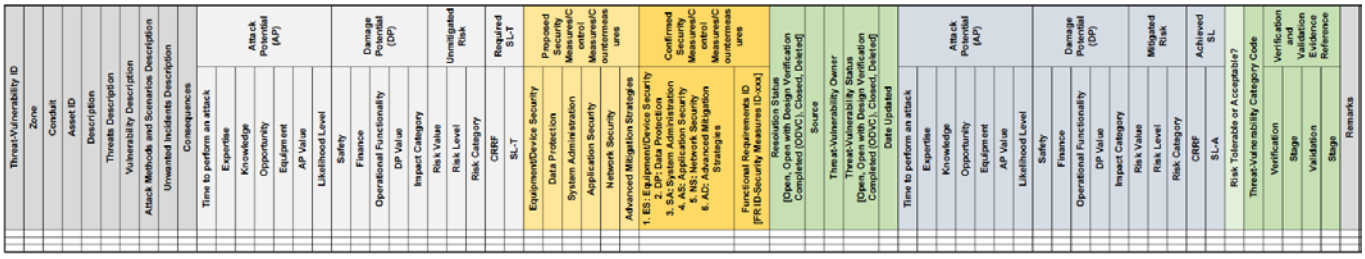


Table A.2. The Proforma Form for Recording the Cyber Threats and Vulnerability Log.



4 Requirements for Security Controls
- (1). Cybersecurity Function Requirements Specification
- (2). Data Protection Countermeasures
- (3). Hardware Protection Countermeasures
- (4). System Administration Countermeasures
- (5). Application Security Countermeasures
- (6). Network Security Countermeasures
- (7). Advanced Mitigation Strategies
- (8). Policies & Procedures Integration Requirements
- (9). Security Level Requirements

A.9 Security Functional Description Specifications (Example)

Preface: The purpose of this document is to document a Project/System Security Functional Description Specifications.

TABLE OF CONTENTS

1 Introduction
- (1). Purposes and Objectives
- (2). Scope of application
- (3). Glossary of Term and Definitions

2 Design Principles for OT-Security
- (1). Secure by Design
- (2). Reduce Attack Surface
- (3). Défense-in-Depth
- (4). Partition and Isolation of Security Zones
- (5). Essential Functions

3 Asset Management
- (1). Asset Baselining
  - a Description relates to 7.2.1-2. (SP06.02BR)
- (2). Asset Inventory Management
  - a Description relates to 7.2.2.-2. & 3. (SP06.02BR)
- (3). Secure Time Authentication and Synchronization
  - a Description relates to 7.4.1.2-2. (SP.03.04 BR).
- (4). Application Control
- (5). Application Error Handling Mechanisms

4 Endpoint Security
- 4.1 Malicious Code Prevention
  - a Description relates to 7.4.1.10-1. (SP.10.01 BR).
  - b Description relates to 7.4.1.10-2. (SP.10.02 BR).
  - c Description relates to 7.4.1.10-2. (1) (SP.10.02 RE (1)).
  - d Description relates to 7.4.1.10-3. (SP.10.03 BR).
  - e Description relates to 7.4.1.10-4. (SP.10.04 BR).
  - f Description relates to 7.4.1.10-5. (SP.10.05 BR).

g Description relates to 7.4.1.10-5. (1). (SP.10.05 RE (1)).
h Description relates to 7.4.1.10-5. (2). (SP.10.05 RE (2)).

4.2 End Point Protection and Management

a Description relates to 7.4.1.2-3. (SP.03.05) BR (Hardening) Endpoint Protection Device; Please describe any Endpoint Protection Device that has been designed, installed, and configured, such as Firewall, Gateway with Firewall, IDS, etc.

4.3 Endpoint Protection Device

a Description relates to 7.4.1.2. (SP.03.06 BR).

4.4 Data Protection in Device

a Description relates to 7.4.1.2.-10. (SP.03.10 BR)
b Description relates to 7.4.1.2.-10. (1) (SP.03.10RE (1))
c Description relates to 7.4.1.2.-10. (2). (SP.03.10RE (2)).
d Description relates to 7.4.1.2.-10. (3). (SP.03.10RE (3)).
e Description relates to 7.4.1.2.-8. (2). (SP.03.08RE (2)).

4.5 Disposal of Systems and Devices

a Description relates to 6.5.3.2 and 6.5.3.3. (SP.03.10RE (4)).

5 Hardening Control

5.1 Application and User Hardening Management

a Description relates to 7.4.1.2-3. (SP.03.05 BR) (Hardening) Identity and Access Management (IAM)

5.2 Certificate Authority (CA) Management

a Description relates to 7.4.1.2-4. (SP.03.05 RE (1) (CA Hardening) Manage that only necessary, authorized, and documented Certificate Authority(CA) digital certificates are installed

6 Identity and Access Management (IAM)

6.1 Use Control and Least Functionality Settings

a Description relates to 7.4.1.2-8. (SP.03.08 BR).

6.2 Internal and External User Access Controls

a Description relates to 7.4.1.8-1. (SP.07.01 BR).
b Description relates to 7.4.1.8-2. (SP.07.02 BR).
c Description relates to 7.4.1.8-3. (SP.07.03 BR).

6.3 Network Assess Controls

a Description relates to 7.4.1.2-1. (SP.03.02 BR).
b Description relates to 7.3.1.1-4. (1) (SP.03.02 RE (1)).
c Description relates to 7.3.1.1-4. (2) & (3). (SP.03.02 RE (2)).
d Description relates to 7.4.1.2-6. (SP.03.07 BR).
e Description relates to 7.4.1.8-1. (SP.07.01 BR).
f Description relates to 7.4.1.8-2. (SP.07.02 BR).
g Description relates to 7.4.1.8-3. (SP.07.03 BR).
h Description relates to 7.4.1.8-4. (SP.07.04 BR).
i Description relates to 7.4.1.8-5. (SP.07.04 RE (1)).

6.4 Application Access Controls

a Description relates to 7.4.1.2-8. (SP.03.08 BR).

b Description relates to 7.4.1.2-8. (1) (SP.03.08 RE (1)).
c Description relates to 7.4.1.2-8. (3) (SP.03.08 RE (3)).

6.5 User Access Rights and Role-based Access Controls

a Description relates to 7.4.1.2-8. (SP.03.08 BR).
b Description relates to 7.4.1.2-8. (1) (SP.03.08 RE (1)).

6.6 Access and Administration Mechanisms

a Description relates to 7.4.1.3.-1. (SP.09.01 BR).
b Description relates to 7.4.1.3.-2. (SP.09.02 BR).
c Description relates to 7.4.1.3.-2. (1). (SP.09.02 RE (1)).
d Description relates to 7.4.1.3.-2. (4). (SP.09.02 RE (4)).
e Description relates to 7.4.1.3.-3. (Description relates to. (SP.09.03 BR).
f Description relates to 7.4.1.3.-4. (SP.09.04 BR).
g Description relates to 7.4.1.3.-5. (SP.09.05 BR).
h Description relates to 7.4.1.3.-6. (SP.09.06 BR).
i Description relates to 7.4.1.3.-6. (1). (SP.09.06 RE (1)).
j Description relates to 7.4.1.3.-8. (SP.09.08 BR).
k Description relates to 7.4.1.3.-9. (SP.09.09 BR).
l Description relates to 7.4.1.3.-9. (1). (SP.09.09 RE (1)).

6.7 User Policy Enforcement

a Description relates to 7.4.1.3.-7. (SP.09.07BR)
b Description relates to 7.4.1.3.-8.(1) SP.09.08RE(1)
c Description relates to 7.4.1.2.-10. (SP.03.10BR).
d Description relates to 7.4.1.2.-10. (2). (SP.03.10RE (2)).
e Description relates to 7.4.1.2.-10. (3). (SP.03.10RE (3)).

7 Security Patching

7.1 Patch Management

a Description relates to 7.4.1.11-2. (SP.11.02 BR).
b Description relates to 7.4.1.11-3. (SP.11.02 RE (1)).
c Description relates to 7.4.1.11-3. (2). (SP.11.02 RE (2)).
d Description relates to 7.4.1.11-4. (SP.11.03 BR).
e Description relates to 7.4.1.11-5. (SP.11.04 BR).
f Description relates to 7.4.1.11-6. (SP.11.05 BR).
g Description relates to 7.4.1.11-7. (SP.11.06 BR).
h Description relates to 7.4.1.11-7. (1). (SP.11.06 RE (1)).
i Description relates to 7.4.1.11-7. (2). (SP.11.06 RE (2))
j Description relates to 7.4.1.11-7. (3). (SP.11.06 RE (3)).

7.2 Validation and Testing

a Description relates to 7.4.1.11-2. (SP.11.01 BR).
b Description relates to 7.4.1.11-2. (1) (SP.11.01 RE (1)).

8 Backup and Restore

8.1 Backup Schedules Configuration

a Description relates to 7.4.1.12.-1. (SP.12.01 BR).
b Description relates to 7.4.1.12.-2. (SP.12.02 BR).
c Description relates to 7.4.1.12.-3. (SP.12.03 BR).

d Description relates to 7.4.1.12.-4. (SP.12.04 BR).
e Description relates to 7.4.1.12.-5. (SP.12.05 BR).
f Description relates to 7.4.1.12.-6. (SP.12.06 BR).
g Description relates to 7.4.1.12.-7. (SP.12.07 BR).
h Description relates to 7.4.1.12.-8. (SP.12.08 BR).
i Description relates to 7.4.1.12.-9. (SP.12.09 BR).

8.2 Recovery Testing Mechanisms

a Description relates to 7.4.1.12.-5. (SP.12.05 BR).

8.3 Device and Network Redundancy Configuration

8.4 Emergency Power Supply Configuration

9 Remote Interactive Access

9.1 Session Logging – Event Management

a Description relates to 7.4.1.9.-3. (SP.08.02 BR).
b Description relates to 7.4.1.9.-3. (2) (SP.08.02 RE (2)).
c Description relates to 7.4.1.9.-4. (SP.08.03 BR).
d Description relates to 7.4.1.9.-4. (1). (SP.08.03 RE (1)).
e Description relates to 7.4.1.9.-5. (SP.08.04 BR).

9.2 Default Credentials Removed

a Description relates to 7.4.1.3.-2. (SP.09.02 BR).
b Description relates to 7.4.1.3.-2. (1). (SP.09.02 RE (1)).
c Description relates to 7.4.1.3.-2. (4). (SP.09.02 RE (4)).

9.3 Multifactor Authentication

a Description relates to 7.4.1.8.-5. (SP.07.04 RE (1)) for Remote Access.
b 2 Description relates to 7.4.1.2. 8.(3) (SP.03.08RE(3)) for Remote Access

10 Network Security

10.1 Network Segmentation

a Description relates to 7.3.1.1-4. (1). (SP.03.02 RE (1)) for Network Security.

10.2 Zoning and Conduits

a Conduct risk assessment to verify that identified untrusted network interfaces have adequate protection
b Description relates to 7.3.1.1-4. (2). (SP.03.02 RE (2)) for Network Security.
c Description relates to 7.3.1.7-6. (SP.05.06BR) for SIS Network Security.
d Description relates to 7.3.1.7-8. (SP.05.08BR) for SIS Network Security.

10.3 Documentation and Schematics

a Description relates to 7.4.1.4-7. (1) & (2) (SP.06.01 BR).
b Description relates to 7.4.1.4-7. (3). (SP.06.06.01 RE (1)).

10.4 Logging and Auditing Controls – Event Management

a Description relates to 7.4.1.9.-3. (SP.08.02 BR).
b Description relates to 7.4.1.9.-4. (SP.08.03 BR).
c Description relates to 7.4.1.9.-4. (1). (SP.08.03 RE (1)).

10.5 Communication Protection

a Description relates to 7.4.1.2.-5. (SP.03.06 BR, Session locking).
b Description relates to 7.4.1.2.-8. (2). (SP.03.08RE (2)).

11 Logging and Auditing – Event Management

11.1 Auditable Events Identification

a Description relates to 7.4.1.9.-3. (SP.08.02 BR).

b Description relates to 7.4.1.9.-3. (2). (SP.08.02 RE (2)).

c Description relates to 7.4.1.9.-4. (SP.08.03 BR).

d Description relates to 7.4.1.9.-4. (1). (SP.08.03 RE (1)).

e Description relates to 7.4.1.9.-5. (SP.08.04 BR).

11.2 User Logging Configuration

a Description relates to 7.4.1.9.-3. (SP.08.02 BR).

b Description relates to 7.4.1.9.-3. (2). (SP.08.02 RE (2)).

c Description relates to 7.4.1.9.-4. (SP.08.03 BR).

d Description relates to 7.4.1.9.-4. (1). (SP.08.03 RE (1)).

e Description relates to 7.4.1.9.-5. (SP.08.04 BR).

11.3 Device Logging Configuration

a Description relates to 7.4.1.9.-3. (SP.08.02 BR).

b Description relates to 7.4.1.9.-3. (2). (SP.08.02 RE (2)).

c Description relates to 7.4.1.9.-4. (SP.08.03 BR).

d Description relates to 7.4.1.9.-4. (1). (SP.08.03 RE (1)).

e Description relates to 7.4.1.9.-5. (SP.08.04 BR).

11.4 Network Logging Configuration

a Description relates to 7.4.1.9.-3. (SP.08.02 BR).

b Description relates to 7.4.1.9.-3. (2). (SP.08.02 RE (2)).

c Description relates to 7.4.1.9.-4. (SP.08.03 BR).

d Description relates to 7.4.1.9.-4. (1). (SP.08.03 RE (1)).

e Description relates to 7.4.1.9.-5. (SP.08.04 BR).

11.5 Security Tools Logging – Malware Protection

a Description relates to 7.4.1.9.-3. (1). (SP.08.02 RE (1)) which related to Security Tools Logging for Malware Protection.

11.6 Threat Detection

a Description relates to 7.4.1.10.-5. (SP10.05 BR).

b Description relates to 7.4.1.10.-5. (1). (SP10.05 RE (1)).

c Description relates to 7.4.1.10.-5. (2). (SP10.05 RE (2)).

11.7 Intrusion Detection and Protection Configuration

a Description relates to 7.4.1.10.-3. (SP10.03 BR) which related to intrusion Detection and Protection Configuration or Malware Protection.

11.8 Monitoring Use Cases

12 Safety Instrumented System (SIS)

12.1 Safety Instrumented System (SIS) security (if applicable)

a Description relates to 7.3.1.-8. (SP.05.01 BR).

b Description relates to 7.4.1.7.-1. (SP.05.02 BR).

c Description relates to 7.4.1.7.-2. (SP.05.03 BP)

d Description relates to 7.4.1.7.-3. (SP.05.04 BP)

e Description relates to 7.4.1.7.-4. (SP.05.05 BP)

f Description relates to 7.4.1.7.-5. (SP.05.05 RE (1))

g Description relates to 7.4.1.7.-6. (SP.05.06 BP)

h Description relates to 7.4.1.7.-7. (SP.05.07 BP)
i Description relates to 7.4.1.7.-8. (SP.05.08 BP)
j Description relates to 7.4.1.7.-9. (SP.05.09 BP)
k Description relates to 7.4.1.7.-9. (1) (SP.05.09 RE (1)).
l Description relates to 7.4.1.7.-9. (2) (SP.05.09 RE (2))

13 Wireless Security

13.1 Wireless Security (if applicable)

a Description relates to 7.4.1.6.-1. (SP.04.01 BP)
b Description relates to 7.4.1.6.-2. (SP.04.02 BP)
c Description relates to 7.4.1.6.-3. (SP.04.02 RE (1))
d Description relates to 7.4.1.6.-4. (SP.04.03 BR)
e Description relates to 7.4.1.6.-5. (SP.04.03 RE (1))
f Description relates to 7.4.1.6.-6. (SP.04.03 RE (2))

A.10 IACS Automation Solutions/Asset Hardening Recommended Practices (Example)

Preface: The purpose of this document is to document a Project/System Asset Hardening Recommended Practices.

TABLE OF CONTENTS

1 Introduction
(1). Purposes and Objectives
(2). Scope of application
(3). Glossary of Term and Definitions
2 Physical hardening
3 Logical hardening
(1). Disabling of physical/logical ports
(2). Hardening of logical network interface
(3). Hardening of software
(4). Application of known patches
(5). Additional hardening
(6). Network equipment checklist
4 Checklist
(1). Server hardening checklist
(2). Network device hardening checklist
(3). Scope of application

A.11 OT Security Inspection and Test Protocol (FAT/SAT Test Case) (Example)

Preface: The purpose of this document is to document the OT Security Inspection and Test Protocol of SuC.

TABLE OF CONTENTS

1 Introduction
(1). Purposes and Objectives
(2). Scope of Application

(3). Glossary of Term and Definitions
(4). Applicable Documents
2 Inspection and Test Planning
(1). Overview
(2). Inspection and Test Categories
3 Inspection and Acceptance Check Forms
(1). Physical Inspection
(2). Physical Security Inspection
(3). Assets Patch, Firmware Inspection
(4). Cybersecurity Function Requirements Inspection and Test
(5). Data Protection Inspection
(6). Hardware Protection Inspection
(7). System Administration Inspection
(8). Application Security Inspection
(9). Network Security Inspection
(10). Advanced Mitigation Strategies Inspection
(11). Policies & Procedures Integration Requirements Inspection
(12). Hardening Requirements Inspection
(13). Vulnerability Scan

A.12 OT Security Vulnerability Scanning Report & Results (Example)

Preface: The purpose of this document is to document the OT Security Vulnerability Scanning Report & Results of SuC.

TABLE OF CONTENTS

1 Introduction
(1). Purposes and Objectives
(2). Scope of Application
(3). Glossary of Term and Definitions
(4). Applicable Documents
2 Vulnerability Assessment Methodology
(1). Scanning Tools and Techniques
(2). Scan Procedure
3 Vulnerability Assessment Findings
(1). Findings Overview
(2). Detailed Vulnerability Findings
a Device 1 :
(a) Vulnerability ID1 : 80331 - PHP 5.5.x < 5.5.20 'process_nested_data' RCE. (Risk Rating: High)
I. Description
Arbitrary code may be run on the remote server.
II. Vulnerable Host & Asset Model
IP#.###.###.### Device_Name
III. Implications

According to its banner, the version of PHP 5.5.x installed on the remote host is prior to 5.5.20. It is, therefore, affected by a use-after-free error in the 'process_nested_data' function within 'ext/standard/var_unserializer.re' due to improper handling of duplicate keys within the serialized properties of an object. A remote attacker, using a specially crafted call to the 'unserialize' method, can exploit this flaw to execute arbitrary code on the system.

Note that Nessus has not attempted to exploit this issue but has instead relied only on the application's self-reported version number.

IV. Recommendations

Upgrade to PHP version 5.5.20 or later.

V. Countermeasures/Actions

i. Request the device vendor to fix the Vulnerability. (Upgrade PHP version)

ii. Request the vendor for providing the temporary suggestion of effective mitigation measures for alternative patches.

iii. Once get the patch file, patch it as soon as possible.

VI. Follow-up Review

4 Appendix I Nessus Scan Configuration

(1). Scan Policy

(2). Credentials

(3). Port scanning

(4). Service Detection

(5). Plugin Selection

(6). Scan Schedule

(7). Assessment Configuration

5 Appendix II Nessus Scan Results

Annexes B: Annexes Related to the Security Policy and Procedure

The practices and tables used for the Security Policy and Procedure are provided in this Annexes.

B.1 Key Competencies of Roles for the Project/System or the Project

The key competencies requirements of roles for the Project/System security management organization are described in

Table B.1 and the key competencies requirements of roles for the project security assurance organization of the Project/System is presented in Table B.2.

Table B.1 Key Competencies of Roles for the Project Security Management Organization.

Role	Key Competencies
Project/System Security Office(P/SSO)	(1) Understand the security requirements of the development process. (2) Be competent in the domain/technologies where independent assessment is carried out. (3) Have practical cyber threats identification, analysis, risk assessment, evaluation, treatment, and management-related technical capabilities Understand the requirements of the security process. (4) Have/Strive to continually gain sufficient levels of experience in the security principles. (5) Be competent in understanding the relevant security, human resource, technical, and quality management processes in fulfilling the requirements of the IEC 62443. (6) Be able to weigh different options and understand the impact on the security performance of a decision or selected options. (7) Understand the requirements of other relevant parts of the IEC 62443 standard.
Project Security (PJS) Leader	(1) Understand quality, competencies, organizational, and management requirements of IEC 62443. (2) Understand the requirements of the security process. (3) Be able to weigh different options and understand the impact on the security performance of a decision or selected options. (4) Understand the requirements of the development process. (5) Understand the requirements of other relevant parts of the IEC 62443 standard.
Security Analysis Center (SAC)	(1) Understand the security requirements of the development process. (2) Be competent in the domain/technologies where independent assessment is carried out. (3) Have practical cyber threats identification, analysis, risk assessment, evaluation, treatment, and management-related technical capabilities Understand the requirements of the security process.

Role	Key Competencies
	(4) Have/Strive to continually gain sufficient levels of experience in the security principles. (5) Be competent in understanding the relevant security, human resource, technical, and quality management processes in fulfilling the requirements of IEC 62443. (6) Be able to weigh different options and understand the impact on the security performance of a decision or selected options. (7) Understand the requirements of other relevant parts of the IEC 62443 standard.
Security Test Center (STC)	(1) Be competent in the domain where validation is carried out. (2) Cybersecurity testing related certification. (3) Have analytical thinking ability and good observation skills. (4) Understand the requirements of IEC 62443. (5) Cybersecurity and privacy principles and organizational requirements (relevant to confidentiality, integrity, availability, authentication, non-repudiation). (6) Cyber threats and vulnerabilities. (7) Specific operational impacts of cybersecurity lapses. (8) Security assessment and authorization process. (9) Hacking methodologies. (10) Knowledge of command-line tools (e.g., mkdir, mv, ls, passwd, grep). (11) Be capable of deriving the types of integration tests from a set of (integrated) security functions.

Table B.2 Key Competencies of Roles for the SI/SM Project Security Management Plan Security Assurance Organization.

Role	Key Competencies
Project Manager (PM)	(1) Understand quality, competencies, organizational, and management requirements of IEC 62243. (2) Understand the requirements of the security process. (3) Be able to weigh different options and understand the impact on the security performance of a decision or selected options. (4) Understand the requirements of the development process. (5) Understand the requirements of other relevant parts of the IEC 62443 standard.
Project Security (PJS) Leader	(1) Understand quality, competencies, organizational and management requirements of IEC 62243. (2) Understand the requirements of the security process. (3) Be able to weigh different options and understand the impact on the security performance of a decision or selected options. (4) Understand the requirements of the development process. (5) Understand the requirements of other relevant parts of the IEC 62443 standard.
Technical Leader (TL)	(1) Understand quality, competencies, organizational and management requirements of IEC 62243. (2) Understand the requirements of the security process. (3) Be able to weigh different options and understand the impact on the security performance of a decision or selected options. (4) Understand the requirements of the development process. (5) Understand the requirements of other relevant parts of the IEC 62443 standard.
Tester (TST)	(1) Be competent in the domain where validation is carried out. (2) Cybersecurity testing related certification. (3) Have analytical thinking ability and good observation skills. (4) Understand the requirements of IEC 62443. (5) Developing operations-based testing scenarios. (6) Writing code in a currently supported programming language (e.g., Java, C++). (Optional) (7) Writing test plans and evaluating test plans for applicability and completeness. (8) Designing and documenting overall program test and evaluation strategies. (9) Identifying test and evaluation infrastructure (people, ranges, tools, instrumentation) requirements. (10) Managing test assets, test resources, and test personnel to ensure effective completion of test events. (11) Preparing test & evaluation reports. (12) Providing test & evaluation resource estimate. (13) Security assessment and authorization process.

Role	Key Competencies
	(14) Network hardware devices and functions. (15) Systems testing and evaluation methods. (16) Systems engineering process. (17) Knowledge of critical infrastructure systems with information communication technology that were designed without system security considerations.
Verifier (VER)	(1) Be competent in the domain where testing, integration, and verification are carried out. (2) Be competent in various test and verification approaches/methodologies and be able to identify the most suitable method or combination of methods in a given context. (3) Be capable of deriving test cases from given specifications. (4) Be competent in understanding the design and functionality required at various intermediate levels. (5) Be capable of deriving the types of verification from given specifications. (6) Have analytical thinking ability and good observation skills. (7) Understand the relevant parts of IEC 62443.
Validator (VAL)	(1) Be competent in the domain where validation is carried out. (2) Be competent in various validation approaches/methodologies and be able to identify the most suitable method or combination of methods in a given context. (3) Be capable of deriving the types of validation evidence required from given specifications bearing in mind the intended application. (4) Be capable of combining different sources and types of evidence and synthesize an overall view about fitness for purpose or constraints and limitations of the application. (5) Have analytical thinking ability and good observation skills. (6) Understand the requirements of IEC 62443.

Role	Key Competencies
Cybersecurity Assessor (CSA) or Independent Security Assessor	(1) Be competent in the domain/technologies where independent assessment is carried out. (2) Have acceptance/license from a recognized security authority, such as the P/SSO and/or the PE/O (contracting body of the assessor). (3) Have/Strive to continually gain sufficient levels of experience in the security principles, secure by design practices, and the application of the principles within the application domain. (4) Be competent to check that a suitable method or combination of methods in a given context has been applied. (5) Be competent in understanding the relevant security, human resource, technical, and quality management processes in fulfilling the requirements of the IEC 62443 (6) Be competent in independent assessment approaches/methodologies. (7) Have analytical thinking ability and good observation skills. (8) Be capable of combining different sources and types of evidence and synthesize an overall view about fitness for purpose or constraints and limitations on application. (9) Have an understanding of the overall system including its application environment. (10) Understand the requirements of IEC 62443.

B.2 Organizational Independence for the Project Security Assurance Organization

The organizational independence requirements are basically planned as follows:

1 SYS/DES/DEV/TL/AN/PR/IMP should be separated to INT/TST and to SVV (VER and VAL).
2 VER and VAL will be suggested to be independent for SL 3 & 4.
3 CSA should be planned if applicable and should be independent of the whole project team.
4 VER and VAL:
  Independent person for SL 1 & 2.
  Independent department for SL 3 & 4.
5 CSA:
  Independent department for SL 1 & 2.
  Independent organization for SL 3 & 4.

For non-functional safety projects, the independence of personnel can follow the independence requirements specified in IEC 62443-4-1 standard to plan. The organizational independence for the project security assurance organization of the Project/System is shown in Table B.3.

Notice that the acronyms used in this section is:

PM – Project Manager
PQM – Project Quality Manager
PJSC – Project Security Committee
PCM – Project Configuration Manager
RQM – Requirements Manager
CUS – External Party (Project/System Users, the Asset Owner, etc.)
SYS – System Engineer
DES – Designer
DEV – Developer
DESH – Designer for HW
DESS – Designer for SW
TL – Technical Leader for SW
AN – Analyst for SW
PR – Programmer for SW
IMP – Implementor, if applicable
INT – Integrator, if applicable
TST – Tester
VER – Verifier
VAL – Validator
CSA - Cybersecurity Assessor

The levels of independence for a project role are defined as follows:

1 Independent person – the person who performs the testing cannot be one of the developers of the Project/System.
2 Independent department – the person who belongs to a member of the project cannot report to the same first-line manager as any developer of the Project/System.
3 Independent organization – the person who belongs to a member of the project cannot be part of the same organization as any developers of the Project/System. An organization can be a separate legal entity, a division of a company, or a department of a company that

reports to a different executive such as a vice president or a similar level.

4 Independent project – the person who belongs to PJSC and CSA shall be independent of the development project.

Table B.3 Organizational Independence for the Project Security Assurance Organization of the Project/System.

Role Independence	**SYS/DES/DEV/TL/AN/PR/IMP**	**INT / TST**	**VER**	**VAL**	**PM**	**PQM/PCM/RQM**	**CSA**	**PSC**
SL1&2								
SYS/DES/DEV/TL/AN/PR/IMP	——	Person	Person	Person	Person	Person	Department & Project	Person & Project
INT / TST	Person	——	Person	Person	Person	Person	Department & Project	Person & Project
VER	Person	Person	——	——	Person	Person	Department & Project	Person & Project
VAL	Person	Person	——	——	Person	Person	Department & Project	Person & Project
PM	Person	Person	Person	Person	——	Person	Department & Project	Person & Project
PQM/PCM/RQM	Person	Person	Person	Person	Person	——	Department & Project	Person & Project
CSA	Department & Project	Department & Project	Department & Project	Department & Project	Department & Project	Department & Project	——	Person
PSC	Person & Project	Person & Project	Person & Project	Person & Project	Person & Project	Person & Project	Person	——
SL 3&4								

Role Independence	SYS/DES/DEV/TL/AN/PR/IMP	INT / TST	VER	VAL	PM	PQM/PCM/RQM	CSA	PSC
SYS/DES/DEV/TL/AN/PR/IMP	——	Person	Person	Person	Person	Person	Organization & Project	Person & Project
INT / TST	Person	——	Person	Person	Person	Person	Organization & Project	Person & Project
VER	Person	Person	——	Department	Person	Person	Organization & Project	Person & Project
VAL	Person	Person	Department	——	Person	Person	Organization & Project	Person & Project
PM	Person	Person	Person	Person	——	Person	Organization & Project	Person & Project
PQM/PCM/RQM	Person	Person	Person	Person	Person	——	Organization & Project	Person & Project
CSA	Organization & Project	Organization & Project	Organization & Project	Organization & Project	Organization & Project	Organization & Project	——	Person
PSC	Person & Project	Person & Project	Person & Project	Person & Project	Person & Project	Person & Project	Person	——

1 Required Level of Independence of Testers from Developers

If the functional safety requirements come from IEC 61508 family standards were not applicable to the Project/System, the following required level of independence of TST/VER/VAL from SYS/DES/DEV/TL/AN/PR/IMP/INT shall comply with Table B.4.

Table B.4 Required Level of Independence of Testers from Developers.

Test type	**Reference**	**Level of independence**			
		Lv1	**Lv2**	**Lv3**	**Lv4**
Security requirement testing	IEC 62443-4-1 SVV-1	Department	Department	Organization	Organization
Threat mitigation testing	IEC 62443-4-1 SVV-2	Department	Department	Organization	Organization
Abuse case testing	IEC 62443-4-1 SVV-3	Person	Person	Person	Person
Static code analysis	IEC 62443-4-1 SI-1	None	None	None	None
Attack surface analysis	IEC 62443-4-1 SVV-3	Person	Department	Organization	Organization
Known vulnerability scanning	IEC 62443-4-1 SVV-3	Person	Person	Person	Person
Software composition analysis	IEC 62443-4-1 SVV-3	None	None	None	None
Penetration testing	IEC 62443-4-1 SVV-4	Department	Organization	Organization	Organization

Notice that the description of each test type will refer to Chapter 9 in the IEC 62443-4-1 standard. The levels of independence of testers/verifier/validator are defined as follows:

None – no independence required. The developer can perform the testing.

Independent person – the person who performs the testing cannot be one of the developers of the Project/System.

Independent department – the person who performs the testing cannot report to the same first-line manager as any developers of the Project/System. Alternatively, they could be a member of a Quality Assurance (QA) department.

Independent organization – the person who performs the testing cannot be part of the same organization as any developers of the Project/System. An organization can be a separate legal entity, a division of a company or a department of a company that reports to a different executive such as a vice president or a similar level.

2 Relationship between Organization

PSO is the official unit of INTELLIGENT CLOUD PLUS which is responsible for ensuring the security of all secure Project/Systems and supporting various secure Project/System development projects.

When a Project/System development project is established, the PSO will assign a person to be the PJSC Leader to assist the project manager in handling security-related work and review in the Concept Phase (R0) of the project.

During secure Project/System development or patching SDL, SAC personnel will be responsible for Project/System security tasks, including threat model, risk assessment, etc, and security review activities, such as reviewing security requirements in R1 Review (C2), reviewing security design in R2 Review (C2), reviewing security implementation in R3 Review (C3). The PJSC and SAC are not involved in the development of secure Projects/Systems.

STC assigns personnel to serve as security testing (TST), safety verification (VER), and safety verification (VAL) roles for a secure Project/System and conduct independent security tests during System Security Acceptance Testing (R3.3).

PSO will also assign personnel or hire external experts to serve as the CSA led by PJSC or additionally assigned to Independent Security Assessor, if applicable or required.

B.3 The Proforma Form for Verifying File Integrity

The following proforma form for verifying that method of file integrity used before releasing.

編號 **Number**		**日期** **Date**	
查核人 **Verifier**		**審查人** **Reviewer**	
產品型號 **Model of Product**		**軟體版本** **Software Version**	
專案型式 **Project Type**	□Initial Release □Major Release □Minor Release □Security Patch □Hot fix		
交付項目 **Deliverable**	**檔案完整性確保方案** **method for file integrity**		**通過(Pass?)**
文件(Document)	☐ Not applicable ☐ Cryptographic Hash ☐ Digital Signature ☐ Other_____		☐ Pass ☐ Not Pass
韌體(Firmware)	☐ Not applicable ☐ Cryptographic Hash ☐ Digital Signature ☐ Other_____		☐ Pass ☐ Not Pass
Script	☐ Not applicable ☐ Cryptographic Hash		☐ Pass ☐ Not Pass

	☐ Digital Signature ☐ Other_____	
(Extend if need)		

B.4 The corresponding Security program process and guidelines

The following table is for corresponding work instructions when executing each process of Security program requirements. XXX_IEC 62443-2-4 Processes and Actions.xls could be used to perform the tasks assignment of SDL.

ID	Requirement	Inputs	Measures	Verification steps	Outputs
SP.01.01BR	The service provider shall have a process that can be performed for the asset owner that it assigns only service provider personnel to Automation Solution related activities who have been informed of and comply with the requirements defined in this document that are required by the asset owner.	ID02 section A.3 5.3b.	(ID01) 7.1.1.1 5.~6. (ID01) 7.1.3 1. (ID02) A.1 (ID03) 5.3.2 (ID01) 7.1.3 3. (ID02) A.3 (ID01) 6.3. (ID01) 7.1.2 1.	ID02 Table C.1 VCSP.16 ~ VCSP.19	ID06_Dummy Project - SI/SM Project Security Management Plan (defined in ID02 section A.3)
SP.01.01RE(1)	The service provider shall have a process that can be performed for the asset owner to assign only subcontractor or consultant personnel to Automation Solution related activities who have been informed of and comply with requirements defined in this document that are required by the asset owner.	ID02 section A.1 8 A.2 5 & 6	(ID01) 7.1.1.1 5. (ID02) A.1 (ID01) 7.1.1.2 3.~7. (ID02) A.2 (ID01) 7.1.3 (ID01) 6.3. (ID01) 7.1.2 1.	ID02 Table C.1 VCSP.01 ~ VCSP.08	ID04_Dummy Project - Security Management Plan (defined in ID02 section A.1) ID05_Dummy Project - Security Vendor Management Plan (defined in ID02 section A.2) ID06_Dummy Project - SI/SM Project Security Management Plan (defined in ID02 section A.3)
SP.01.02BR	The service provider shall have a process that can be performed for the asset owner to assign only service provider, subcontractor or consultant personnel to Automation Solution related activities who have been informed of and comply with the security-related responsibilities, policies, and procedures, in addition to those specified in this document, required by the asset owner.	ID02 section A.1 7 A.2 5.1 A.3 5.2b	(ID01) 7.1.1.1 1. (ID02) A.1 (ID01) 7.1.1.2 1. (ID02) A.2 (ID01) 7.1.1.4 (ID01) 7.1.3	ID02 Table C.1 VCSP.02, VCSP.07, & VCSP.21	ID04_Dummy Project - Security Management Plan (defined in ID02 section A.1) ID05_Dummy Project - Security Vendor Management Plan (defined in ID02 section A.2) ID06_Dummy Project - SI/SM Project Security Management Plan (defined in ID02 section A.3)
SP.01.02RE(1)	The service provider shall have a process that can be performed for the asset owner to assign only service provider, subcontractor or consultant personnel to Automation Solution related activities who have been informed of and comply with the asset owner's processes for change management and work permits involving automation components and associated connections, often called Management of Change (MoC)and Permit To Work (PtW).	ID02 section A.1 12 A.2 5.1 A.3 5.2b	(ID01) 7.1.1.1 2. (ID02) A.1 (ID01) 7.1.1.2 2. (ID02) A.2 (ID01) 7.1.1.3 1. (ID01) 7.1.3 3. (ID02) Annexes A.1 12.	ID02 Table C.1 VCSP.03, VCSP.08 & VCSP.22	ID04_Dummy Project - Security Management Plan (defined in ID02 section A.1) ID05_Dummy Project - Security Vendor Management Plan (defined in ID02 section A.2) ID06_Dummy Project - SI/SM Project Security Management Plan (defined in ID02 section A.3)
SP.01.03BR	The service provider shall have a process that can be performed for the asset owner to assign only service provider personnel to Automation Solution related activities who have been informed of and comply with the policies, procedures, and contractual obligations required to protect the confidentiality of the asset owner's data.	ID02 section A.3 5.2b	(ID01) 7.1.1.1 4.~7. (ID01) 7.1.1.3 (ID01) 7.1.3 1. (ID01) 7.1.3 1. & 4. (ID03) 5.2.1 (ID04) 7.0	ID02 Table C.1 VCSP.23	ID06_Dummy Project - SI/SM Project Security Management Plan (defined in ID02 section A.3)
SP.01.03RE(1)	The service provider shall have a process that can be performed for the asset owner to assign only subcontractors, consultants, and representatives to Automation Solution related activities who have been informed of and comply with the policies and procedures required to protect the confidentiality of the asset owner's data.	ID02 section A.1 5 & 7 A.2 5	(ID01) 7.1.3 1. & 4. (ID01) 7.1.3 4. (ID04) 7.0 (ID05) 5.2	ID02 Table C.1 VCSP.04 ~ VCSP.08-1	ID04_Dummy Project - Security Management Plan (defined in ID02 section A.1)
SP.01.04BR	The service provider shall have a process that can be performed for the asset owner to assign only service provider personnel to Automation Solution related activities who have successfully passed security-related background checks, where feasible, and to the extent allowed by applicable law.	ID02 section A.3 5.3c(a)	(ID01) 7.1.1.3 2. (ID01) 7.1.2 3.	ID02 Table C.1 VCSP.16	ID06_Dummy Project - SI/SM Project Security Management Plan (defined in ID02 section A.3)
SP.01.04RE(1)	The service provider shall have a process that can be performed for the asset owner to assign only subcontractors, consultants, and representatives to Automation Solution related activities who have successfully passed security-related background checks where feasible, and to the extent allowed by applicable law.	ID02 section A.3 5.3c(a)	(ID01) 7.1.1.3 2. (ID01) 7.1.2 3. (ID05) 8.0	ID02 Table C.1 VCSP.16	ID06_Dummy Project - SI/SM Project Security Management Plan (defined in ID02 section A.3)
SP.01.05BR	The service provider shall have a process that can be performed for the asset owner to assign a security contact in its organization to the Automation Solution who is responsible and accountable for the following activities. 1) Acting as liaison with the asset owner, as appropriate, about the service provider's and the Automation Solution's adherence to the requirements of	ID02 section A.3 5.3d	(ID01) 7.1.1.3 3. (ID01) 6.2.2. (ID03) 5.3.4 1.	ID02 Table C.1 VCSP.17	ID06_Dummy Project - SI/SM Project Security Management Plan (defined in ID02 section A.3)

ID	Requirement	Inputs	Measures	Verification steps	Outputs
	this document that are required by the asset owner. 2) Communicating the service provider's point-of-view on IACS security to the asset owner'sstaff. 3) Ensuring that tenders to the asset owner are aligned and incompliance with the requirements of this document specified as required by the asset owner and the service provider's internal IACS security requirements. 4) Communicating to the asset owner deviations from, or other issues not conforming with, the requirements of this document that are required by the asset owner. This includes deviations between these requirements and the service provider's internal requirements.				
SP.01.06BR	The service provider shall have a process that can be performed for the asset owner to document minimum IACS cyber-security qualifications for security lead positions and the capability to assign security leads to Automation Solutions who meet these qualifications.	ID02 section A.3 5.3d	(ID01) 7.1.1.3 4. (ID03) 5.3.2 (ID03) 5.3.3	ID02 Table C.1 VCSP.18	ID06_Dummy Project - SI/SM Project Security Management Plan (defined in ID02 section A.3)
SP.01.07BR	The service provider shall have a process that can be performed for the asset owner to notify the asset owner of changes in service provider, subcontractor, or consultant personnel who have access to the Automation Solution.	ID02 section A.3 5.3d	(ID01) 7.1.1.3 5. (ID03) 5.3.4 1.	ID02 Table C.1 VCSP.19	ID06_Dummy Project - SI/SM Project Security Management Plan (defined in ID02 section A.3)
SP.02.01BR	The service provider shall have a process to provide the asset owner with documentation that verifies that Automation Solution components for which the service provider is responsible have adequate security for their level of risk.	ID02 section A.8	(ID01) 7.2 (ID01) 7.2.1 (ID01) 7.2.1 9. (ID01) 7.3.1 9. (ID02) A.8 (ID01) 7.5 (ID01) 7.4.1.1 1. (ID01) 6.5.1.4.1 (ID01) 7.6.1 1(3) (ID03) 5.6	ID02 Table C.2	ID11_Dummy Project - Threat and Risk Assessment Report (defined in ID02 section A.8)
SP.02.02BR	The service provider shall have a process that can be performed for the asset owner to recommend security analysis tools (e.g. network scanning tools) for use with the Automation Solution and: 1) identify the purpose for their use, 2) provide instructions on how to use them, 3) identify any known adverse effects they can have on the performance of Automation Solution, and 4) provide recommendations on how to avoid adverse effects.	ID02 section A.4	(ID01) 7.4.1.1 2. (ID01) 7.5 1.(1) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(1)[1]	ID02 Table C.1	ID07_Dummy Project - Security Policies and Procedures Plan (defined in ID02 section A.4)
SP.02.02RE(1)	The service provider shall have a process that can be performed for the asset owner to obtain approval from the asset owner prior to using security analysis tools (e.g. network scans) at the asset owner's site.	ID02 section A.4	(ID01) 6.5.1.2.4 2. (ID01) 7.1.1.4 2. (ID01) 7.1.2	ID02 Table C.1	ID07_Dummy Project - Security Policies and Procedures Plan (defined in ID02 section A.4)
SP.02.02RE(2)	The service provider shall have a process that can be performed for the asset owner to schedule and use security analysis tools to discover undocumented and/or unauthorized systems or vulnerabilities in the Automation Solution. This process shall include the ability to use these tools in accordance with the asset owner's standard operating procedures.	ID02 section A.11	(ID01) 7.5 1.(1) (ID01) 7.6.1 1.(1) (ID01) 7.6.1 3.(1) (ID01) 6.5.2.1 (ID01) 7.7.1	ID02 Table C.7 ID02 Table C.8	ID14_Dummy Project - Dummy Project - OT Security Inspection and Test Protocol (FAT/SAT Test Case) (defined in ID02 section A.11)
SP.02.02RE(3)	The service provider shall have a process that can be performed for the asset owner to demonstrate to the asset owner that the control system components used in the Automation Solution have the ability to maintain operation of essential control system functions in the presence of system and/or network scans during normal operation.	ID02 section A.4 ID02 section A.9	(ID01) 7.1.1.4 2. (ID01) 7.5 1.(1) (ID01) 7.6.1 1.(1) (ID01) 7.6.1 3.(1)	ID02 Table C.8	ID07_Dummy Project - Security Policies and Procedures Plan (defined in ID02 section A.4) ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.02.03BR	The service provider shall have a process to provide the asset owner with documentation that describes how to harden the Automation Solution.	ID02 section A.10	(ID01) 7.4.1.5 (ID01) 7.5 5.(1) (ID01) 7.6.1 1.(2) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(5)[1]	ID02 Table C.6 ID02 Table C.7	ID13_Dummy Project - IACS Automation Solutions/Asset Hardening Recommended Practices (defined in ID02 section A.10)
SP.02.03RE(1)	The service provider shall have a process that can be performed for the asset owner to ensure that its security hardening guidelines and procedures are followed during Automation Solution related activities.	ID02 section A.10	(ID01) 7.4.1.5 (ID01) 7.5 5.(1) (ID01) 7.6.1 1.(2) (ID01) 7.6.1 3.(2) (ID01) 7.6.1 2.(5)[1] (ID01) 6.5.1.2	ID02 Table C.7	ID13_Dummy Project - IACS Automation Solutions/Asset Hardening Recommended Practices (defined in ID02 section A.10)
SP.03.01BR	The service provider shall have a process that can be performed for the asset owner to conduct a security risk assessment of the Automation Solution or contribute to(participate in) a security risk assessment conducted by the asset owner or its agent. NOTE 9 See IEC 62443-2-1 for asset owner risk assessment requirements. NOTE 10 See IEC 62443-3-2 for using risk assessments to define zones and conduits. NOTE 11 The asset owner can additionally require the service provider to document its assessment. The "Doc?" column is set to "No "because this is a requirement to have a capability to perform the assessment and not a requirement to provide documentation.	ID02 section A.9	(ID01) 7.2.1 4.~7. (ID01) 7.3.1 3.	ID02 Table C.2 ID02 Table C.6	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.03.01RE(1)	The service provider shall have a process that can be performed for the asset owner to inform the asset owner of the results of security risk assessments that it performs on the Automation Solution, including risk mitigation mechanisms and procedures.	ID02 section A.9	(ID01) 7.2.1 9. (ID01) 7.3.1 7. (ID01) 6.5.1.3.2-2.	ID02 Table C.2 ID02 Table C.6	ID12_Dummy Project - Security Functional Description Specifications

ID	Requirement	Inputs	Measures	Verification steps	Outputs
					(O&M Manual) (defined in ID02 section A.9)
SP.03.01RE(2)	The service provider shall have a process that can be performed for the asset owner to verify that security architecture reviews and/or security assessment and/or threat analysis of the control system used in the Automation Solution have been conducted by an independent party acceptable to the asset owner.	ID02 section A.5 ID02 section A.8	(ID01) 6.5.1.2.4 5. (ID01) 7.2.1 8.	ID02 Table C.2 ID02 Table C.3 ID02 Table C.4	ID08_Dummy Project - Data Flow Diagram (defined in ID02 section A.5) ID11_ Dummy Project - Threat and Risk Assessment Report (defined in ID02 section A.8)
SP.03.02BR	The service provider shall have a process that can be performed for the asset owner to ensure that the Automation Solution communication architecture, including its use of network security devices or equivalent mechanisms, is implemented according to the Automation Solution design as specified and approved by the asset owner.	ID02 section A.9	(ID01) 7.4.1.2 1. (ID01) 7.5 2.(6) (ID01) 7.6.1 2.(2)[13] (ID01) 7.6.1 3.(3)	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9) ID14_Dummy Project - OT Security Inspection and Test Protocol (FAT/SAT Test Case)
SP.03.02RE(1)	The service provider shall have a process that can be performed for the asset owner to identify and document the communication segments of the Automation Solution and their interfaces to other segments, including external networks, and for each interface designate whether it is trusted or untrusted.	ID02 section A.9	(ID01) 7.3.1.1 4. (1) (ID01) 7.5 2.(7) (ID01) 7.6.1 2.(2)[14]	ID02 Table C.4 ID02 Table C.6	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.03.02RE(2)	The service provider shall have a process that can be performed for the asset owner to ensure that interfaces of the Automation Solution that have been identified as untrusted are protected by network communication security devices or equivalent mechanisms, and to document how these interfaces are protected, including Automation Solution specific security policies and rules. NOTE 17 For some, responsibility for maintaining security policies and rules and their documentation is transferred to the asset owner prior to or at Automation Solution turnover.	ID02 section A.9	(ID01) 7.3.1.1 4.(2)~(3) (ID01) 7.5 2.(8) (ID01) 7.6.1 2.(2)[15]	ID02 Table C.4 ID02 Table C.6	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.03.03BR	The service provider shall have a process that can be performed for the asset owner for managing(identifying, assessing, addressing, and disclosing) vulnerabilities that affect the Automation Solution, including its related policies and procedures. These capabilities shalladdress: 1) the management of vulnerabilities newly discovered in the Automation Solution or in its related policies and procedures for which the service provider is responsible, and 2) the management of publicly disclosed vulnerabilities affecting the Automation Solution	ID02 section A.4	(ID01) 6.5.1.2.4 6. (ID01) 7.1.1.4 2. (ID01) 7.5 2.(9)(ID01) 7.6.1 1.(1) (ID01) 7.6.1 2.(2)[16] (ID01) 7.6.1 3.(1)	ID02 Table C.6 ID02 Table C.7 ID02 Table C.8	ID07_Dummy Project - Security Policies and Procedures Plan (defined in ID02 section A.4)
SP.03.03RE(1)	The service provider shall have a process that can be performed for the asset owner to provide documentation to the asset owner that describes how to mitigate security weaknesses inherent in the design and/or implementation of communication protocols used in the Automation Solution that were known prior to Automation Solution integration or maintenance activities.	ID02 section A.4	(ID01) 6.5.1.2.4 6. (ID01) 7.1.1.4 2. (ID01) 7.5 2.(10) (ID01) 7.6.1 2.(2)[17] (ID01) 7.6.1 1.(1) (ID01) 7.6.1 3.(1)	ID02 Table C.6 ID02 Table C.7 ID02 Table C.8	ID07_Dummy Project - Security Policies and Procedures Plan (defined in ID02 section A.4)
SP.03.04BR	The service provider shall have a process that can be performed for the asset owner to ensure that time distribution/synchronization for the Automation Solution: 1) is performed from a secure and accurate source, and 2) uses a protocol that is commonly accepted by both the security and industrial automation communities.	ID02 section A.9	(ID01) 7.4.1.2 2. (ID01) 7.5 2.(11) (ID01) 7.6.1 2.(2)[18] (ID01) 7.6.1 2.(2)[1]	ID02 Table C.6	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.03.05BR	The service provider shall have a process that can be performed for the asset owner to ensure that only software and hardware features required by the Automation Solution or approved by the asset owner are enabled in the Automation Solution. At a minimum, this includes ensuringthat: 1) unnecessary software applications and services (e.g. email, office applications, games)and their associated communication access points(e.g. TCP/UDP ports), USB devices (e.g. mass storage),Bluetooth and wireless communications are disabled and/or removed unless required and authorized for the Automation Solution, 2) network addresses in use areauthorized, 3) physical and logical access to diagnostic and configuration ports is protected from unauthorized access and use, 4) unused ports on network devices(e.g. switches and routers) a reconfigured to prevent unauthorized access to the network infrastructure of the Automation Solution, and 5) maintenance processes maintain the hardened state of the Automation Solution during its lifetime	ID02 section A.9 ID02 section A.10	(ID01) 7.4.1.2 3. (ID01) 7.5 2.(12) (ID01) 7.6.1 2.(2)[19] (ID01) 7.6.1 2.(2)[2]	ID02 Table C.6	ID02 section A.9 ID13_Dummy Project - IACS Automation Solutions/Asset Hardening Recommended Practices (defined in ID02 section A.10)
SP.03.05RE(1)	The service provider shall have a process that can be performed for the asset owner to verify that only necessary, authorized, and documented Certificate Authority(CA) digital certificates are installed.	ID02 section A.9	(ID01) 7.4.1.2 4. (ID01) 7.5 2.(13) (ID01) 7.6.1 2.(2)[20] (ID01) 7.6.1 2.(2)[3]	ID02 Table C.6	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.03.06BR	The service provider shall have a process that can be performed for the asset owner to ensure that session locking is enabled for Automation Solution workstations as required by the asset owner. This requirement	ID02 section A.9	(ID01) 7.4.1.2 5. (ID01) 7.5 2.(14)(ID01) 7.6.1 2.(2)[21]	ID02 Table C.6	ID12_Dummy Project - Security Functional Description Specifications

ID	Requirement	Inputs	Measures	Verification steps	Outputs
	applies only to the workstations for which the service provider is responsible. Session locking: 1) prevents information on the logged-on user's display device from being viewed, and 2) blocks input from the user's input device (e.g. keyboard, mouse)until unlocked by the session user or an administrator. NOTE 19 Locking the user input device means that the user at the workstation is not able to use the keyboard except for unlocking the keyboard.		(ID01) 7.6.1 2.(2)[4]		(O&M Manual) (defined in ID02 section A.9)
SP.03.07BR	The service provider shall have a process that can be performed for the asset owner to ensure that wired and wireless workstations, including handhelds, used for maintenance and engineering of wired and wireless control/instrumentation devices are installed and configured to avoid security risks associated with the circumvention of: 1) Automation Solution's access controls for these devices, 2) communication security safeguards (e.g. network security devices) at the Automation Solution boundary with Level 3. NOTE 20 Direct access to these devices by handhelds that bypass access controls of the Automation Solution is discouraged. NOTE 21 Direct access by a handheld to a wireless device in Level 3 that bypasses the Level 2/3communication security device is discouraged.	ID02 section A.4 ID02 section A.9	(ID01) 7.4.1.2 6. (ID01) 7.5 2.(1) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(2)[5]	ID02 Table C.6	ID07_Dummy Project - Security Policies and Procedures Plan (defined in ID02 section A.4) ID02 section A.9
SP.03.07RE(1)	The service provider shall have a process that can be performed for the asset owner to ensure the use of multi-factor authentication for Automation Solution workstations as required by the asset owner. This requirement applies only to the workstations for which the service provider is responsible.	ID02 section A.9	(ID01) 7.4.1.2 7. (ID01) 7.5 2.(2) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(2)[6]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.03.08BR	The service provider shall have a process that can be performed for the asset owner to configure the use of least privilege for the administration of network devices for which the service provider is responsible.	ID02 section A.9	(ID01) 7.4.1.2 8. (ID01) 7.5 2.(3) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(2)[7]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.03.08RE(1)	The service provider shall have a process that can be performed for the asset owner to configure network device access controls, including those for wireless network devices, as required by the asset owner. NOTE 22 Normally network devices are only accessed by users who areas signed the role of administrator. However, the asset owner's operating procedures can allow access to the network devices by other roles.	ID02 section A.9	(ID01) 7.4.1.2 8.(1) (ID01) 7.5 2.(3) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(2)[7]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.03.08RE(2)	The service provider shall have a process that can be performed for the asset owner to apply security measures to protect the confidentiality and integrity of data, in transit or at rest, that is used in the administration of communication devices (e.g. passwords, configuration data) and that is identified as data requiring safeguarding as specified in SP.03.10 BR and its REs. NOTE 23 See SP.03.10 RE(3) for cryptographic requirements.	ID02 section A.9	(ID01) 7.4.1.2 8.(2) (ID01) 7.5 2.(3) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(2)[7]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.03.08RE(3)	The service provider shall have a process that can be performed for the asset owner to ensure that mutual authentication is used for the administration of communication devices as required by the asset owner.	ID02 section A.9	(ID01) 7.4.1.2 8.(3) (ID01) 7.5 2.(3) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(2)[7]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.03.09BR	The service provider shall have a process that can be performed for the asset owner to ensure that access to the Automation Solution's control actions and data flows in the Automation Solution (e.g. between workstations and controllers),including configuration changes, are: 1) valid, 2) initiated or approved by an authorized user, and 3) transferred over an approved communication path in the approved direction.	ID02 section A.9 ID02 section A.5	(ID01) 7.4.1.2 9. (ID01) 7.5 2.(4) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(2)[8]	ID02 Table C.6 ID02 Table C.7	ID02 section A.9 ID02 section A.5 ID08 Dummy Project - Data Flow Diagram.pdf
SP.03.10BR	The service provider shall have a process that can be performed for the asset owner to identify and document 1) data storage points and dataflows within the Automation Solution that require safeguarding, as defined or approved by the asset owner, and 2) the security requirements for their safeguarding (e.g. confidentiality, integrity, availability).	ID02 section A.9	(ID01) 7.3.1 4. (4) (ID01) 7.4.1.2 10. (ID01) 7.5 2.(5) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(2)[9]	ID02 Table C.6	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.03.10RE(1)	The service provider shall have a process that can be performed for the asset owner to ensure that access controls of the Automation Solution are configured to protect data within the Automation Solution requiring safeguarding, as described in SP 03.10 BR, from unauthorized disclosure or modification, whether at rest or in transit.	ID02 section A.9	(ID01) 7.3.1 4. (4) (ID01) 7.4.1.2 10.(1) (ID01) 7.5 2.(5) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(2)[10]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.03.10RE(2)	The service provider shall have a process that can be performed for the asset owner to provide documentation to the asset owner that describes the retention capabilities provided by the Automation Solution for storing/archiving sensitive data. This documentation includes capacities, pruning and purging functions, retention timeouts, etc.	ID02 section A.9	(ID01) 7.4.1.2 10.(2) (ID01) 7.5 2.(5) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(2)[11]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.03.10RE(3)	The service provider shall have a process that can be performed for the asset owner to ensure that the Automation Solution is configured to use cryptographic mechanisms, including algorithms and key management/distribution/protection, that are commonly accepted by both the security and industrial automation communities, and inform the asset owner of the results of the configuration upon request by the asset owner.	ID02 section A.9	(ID01) 7.4.1.2 10.(3) (ID01) 7.5 2.(5) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(2)[12]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)

ID	Requirement	Inputs	Measures	Verification steps	Outputs
SP.03.10RE(4)	The service provider shall have a process that can be performed for the asset owner to permanently destroy/delete all data in the component requiring safeguarding, as described in SP 03.10 BR, when it removes that component from the Automation Solution.	ID02 section A.3 ID02 section A.9	(ID01) 6.5.3.2 (ID01) 6.5.3.4 1.	ID02 Table C.1 ID02 Table C.6	ID06_Dummy Project - SI/SM Project Security Management Plan (defined in ID02 section A.3) ID02 section A.9
SP.04.01BR	The service provider shall have a process that can be performed for the asset owner to keep its Automation Solution architecture documentation describing wireless systems current in its description of the following: 1) data exchange to/from wireless instrumentation, 2) data exchange through a secure wireless link, 3) security mechanisms that prevent an intruder from gaining access to the Automation Solution using the wireless system, 4) security mechanisms that restrict access within the Automation Solution by workers with handheld wireless devices, 5) where required, security mechanisms that provide protection for remote management of wireless systems. NOTE 28 Zones and conduits as described in IEC 62443-3-2 are often used to define the security boundaries associated with wireless access to wired devices/workstations in the Automation Solution.	ID02 section A.9	(ID01) 7.3.1 5. (ID01) 7.4.1.6 1. (ID01) 7.5 6.(1) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(6)[1]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.04.02BR	The service provider shall have a process that can be performed for the asset owner to ensure that the Automation Solution to protect access is configured to use wireless authentication and access control mechanisms that are commonly accepted by both the security and industrial automation communities.	ID02 section A.9	(ID01) 7.4.1.6 2. (ID01) 7.5 6.(2) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(6)[2]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.04.02RE(1)	The service provider shall have a process that can be performed for the asset owner to ensure that the Automation Solution is configured to protect wireless communications, and if cryptographic mechanisms are used for this purpose, they are commonly accepted by both the security and industrial automation communities.	ID02 section A.9	(ID01) 7.4.1.6 3. (ID01) 7.5 6.(3) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(6)[3]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.04.03BR	The service provider shall have a process that can be performed for the asset owner to provide documentation to the asset owner that indicates whether wireless protocols used in the Automation Solution are compliant with standards commonly used within the industrial security community and with applicable regulations.	ID02 section A.9	(ID01) 7.3.1 6. (ID01) 7.4.1.6 4. (ID01) 7.6.1 2.(6)[4]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.04.03RE(1)	The service provider shall have a process that can be performed for the asset owner to ensure that unique, Automation Solution-specific identifiers used for wireless networks are descriptive, but do not allow an external listener to identify the physical wireless network, its location, or owner of the wireless network.	ID02 section A.9	(ID01) 7.3.1 6. (ID01) 7.4.1.6 5. (ID01) 7.5 6.(4) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(6)[5]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.04.03RE(2)	The service provider shall have a process that can be performed for the asset owner to: 1) configure the Automation Solution's wireless device addresses, and 2) verify their correct assignment.	ID02 section A.9	(ID01) 7.3.1 6. (ID01) 7.4.1.6 6. (ID01) 7.5 6.(5) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(6)[6]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.05.01BR	The service provider shall have a process that can be performed for the asset owner to verify that security architecture reviews and/or security risk assessments of the communications of the SIS used in the Automation Solution have been conducted and addressed.	ID02 section A.9	(ID01) 7.3.1 8. (ID01) 7.3.2 1. (ID01) 7.3.2 2. (ID01) 7.6.1 2.(7)[1]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.05.02BR	The service provider shall have a process that can be performed for the asset owner to configure the Automation Solution to protect SIS safety communications and SIS safety functions from the BPCS or any other Automation Solution communications. NOTE 29 This requirement does not require that communications not critical to safety functions between the SIS and the BPCS (e.g. configuration downloads, status monitoring, logging) be shielded from other Automation Solution communications.	ID02 section A.9	(ID01) 7.4.1.7 1. (ID01) 7.5 7.(1) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(7)[2]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.05.03BR	The service provider shall have a process that can be performed for the asset owner to ensure that communications external to the Automation Solution, including remote access communications, are not able to interfere with the operation of the SIS.	ID02 section A.9	(ID01) 7.4.1.7 2. (ID01) 7.5 7.(2) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(7)[3]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.05.04BR	The service provider shall have a process that can be performed for the asset owner to ensure that applications (e.g. control system applications) external to the SIS are not able to participate in or disrupt or otherwise interfere with SIS communications that are critical to safety functions.	ID02 section A.9	(ID01) 7.4.1.7 3. (ID01) 7.5 7.(3) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(7)[4]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.05.05BR	The service provider shall have a process that can be performed for the asset owner to ensure that SISEWSs that reside outside the SIS(external to SIS interface with the control system) are protected from compromise by communications from Level 3 or above. NOTE 30 The term "Level" refers to the position in the Purdue Reference Model as standardized by ISA 95 and IEC 62264-1 (see 5.3).	ID02 section A.9	(ID01) 7.4.1.7 4. (ID01) 7.5 7.(4) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(7)[5]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.05.05RE(1)	The service provider shall have a process that can be performed for the asset owner to ensure that the Automation Solution's SIS EWSs that reside within the SIS (internal to SIS interface with the control system) are protected from compromise by remote access (e.g. RDP).	ID02 section A.9	(ID01) 7.4.1.7 5. (ID01) 7.5 7.(5) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(7)[6]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)

ID	Requirement	Inputs	Measures	Verification steps	Outputs
SP.05.06BR	The service provider shall have a process that can be performed for the asset owner to ensure that all access to the Automation Solution's SIS from outside the SIS is mediated and authorized at the interface to the SIS.	ID02 section A.9	(ID01) 7.4.1.7 6. (ID01) 7.5 7.(6) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(7)[7]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.05.07BR	The service provider shall have a process that can be performed for the asset owner to ensure that SIS functions performed by the Automation Solution's SIS EWSs are protected from compromise by other SIS EWS software.	ID02 section A.9	(ID01) 7.4.1.7 7. (ID01) 7.5 7.(7) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(7)[8]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.05.08BR	The service provider shall have a process that can be performed for the asset owner to ensure that unauthorized wireless devices are not used as an integral part of SIS safety functions.	ID02 section A.9	(ID01) 7.4.1.7 8. (ID01) 7.5 7.(8) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(7)[9]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.05.09BR	The service provider shall have a process that can be performed for the asset owner to enable and disable SIS configuration mode. While disabled, this interface shall prohibit the SIS from being configured. NOTE 32 This interface will typically prevent configuration messages from being delivered to the SIS.	ID02 section A.9	(ID01) 7.4.1.7 9. (ID01) 7.5 7.(9) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(7)[10]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.05.09RE(1)	The service provider shall have a process that can be performed for the asset owner to enable and disable a hardware implementation of the configuration mode interface required by SP.05.09 BR and to physically lock this hardware implementation while configuration mode is disabled.	ID02 section A.9	(ID01) 7.4.1.7 9.(1) (ID01) 7.5 7.(9) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(7)[10]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.05.09RE(2)	The service provider shall have a process that can be performed for the asset owner to have an independent 3rd party verify that it is not possible to change the configuration of the SIS when the hardware interface described in SP.05.09 RE(1) is locked in the "disable" configuration mode.	ID02 section A.9	(ID01) 7.4.1.7 9.(2) (ID01) 7.5 7.(9) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(7)[10]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.06.01BR	The service provider shall have a process that can be performed for the asset owner to provide accurate logical and physical infrastructure drawings/documentation of the Automation Solution, including its network devices, internal interfaces, and external interfaces. The documentation and drawings shall be maintained as an accurate representation of the Automation Solution.	ID02 section A.9	(ID01) 7.2.1 1. (ID01) 7.2.1 3. (ID01) 6.5.1.2.4 3. (ID01) 7.4.1.4 2.(1) (ID01) 7.4.1.4 2.(2) (ID01) 7.5 4.(1) (ID01) 7.5 4.(2) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(4)[1] (ID01) 7.6.1 2.(4)[2]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.06.01RE(1)	The service provider shall have a process that can be performed for the asset owner to keep the as-built and installed equipment connection and configuration documents current.	ID02 section A.9	(ID01) 7.3.1 1. (ID01) 7.3.1 2. (ID01) 7.4.1.4 2.(3) (ID01) 7.5 4.(3) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(4)[1]	ID02 Table C.2 ID02 Table C.4 ID02 Table C.6	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.06.02BR	The service provider shall have a process that can be performed for the asset owner to create and maintain an inventory register, including version numbers and serial numbers, of all devices and their software components in the Automation Solution for which the service provider is responsible.	ID02 section A.9	(ID01) 7.2.1 2. (ID01) 6.5.1.2.4 3. (ID01) 7.2.2 3.	ID02 Table C.2 ID02 Table C.4 ID02 Table C.6	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.06.03BR	The service provider shall have a process that can be performed for the asset owner to verify that wired and wireless devices used for control and instrumentation have been configured correctly with their approved values.	ID02 section A.9	(ID01) 7.2.2 3. (ID01) 7.4.1.4 2.(4) (ID01) 7.6.1 2.(4)[3]	ID02 Table C.2 ID02 Table C.4 ID02 Table C.6	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.07.01BR	The service provider shall have a process that can be performed for the asset owner to ensure that all remote access applications used in the Automation Solution are commonly accepted by both the security and industrial automation communities.	ID02 section A.9	(ID01) 7.4.1.8 1. (ID01) 7.5 8.(1) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(8)[1]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.07.02BR	The service provider shall have a process that can be performed for the asset owner to provide detailed instructions for the installation, configuration, operation, and termination of the remote access applications to be used in the Automation Solution.	ID02 section A.9	(ID01) 7.4.1.8 2. (ID01) 7.5 8.(2) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(8)[2]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.07.03BR	The service provider shall have a process that can be performed for the asset owner to provide information about all proposed remote access connections to the asset owner that includes, for each connection: 1) its purpose, 2) the remote access application to be used, 3) how the connection will be established (e.g. via the Internet through a VPN), and 4) the location and identity of the remote client.	ID02 section A.9	(ID01) 7.4.1.8 3. (ID01) 7.5 8.(3) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(8)[3]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.07.04BR	The service provider shall have a process that can be performed for the asset owner to ensure that it obtains approval from the asset owner prior to using each and every remote access connection.	ID02 section A.9	(ID01) 7.4.1.8 4. (ID01) 7.5 8.(4) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(8)[4]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)

ID	Requirement	Inputs	Measures	Verification steps	Outputs
SP.07.04RE(1)	The service provider shall have a process that can be performed for the asset owner to ensure that all remote access connections conducted over the Internet or over other publicly accessible media that are used to support remote access to the Automation Solution by the service provider (e.g. from a service provider facility) are protected as required by the asset owner.	ID02 section A.9	(ID01) 7.4.1.8 5. (ID01) 7.5 8.(5) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(8)[5]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.08.01BR	The service provider shall have a process that can be performed for the asset owner to ensure that the Automation Solution is configured to select and handle cyber-security incidents that affect the Automation Solution that includes: 1) which cyber-security compromises and incidents to detect, 2) which cyber-security incidents to report to the asset owner, 3) which cyber-security compromises and incidents need a response, that can include supporting an incident response team. NOTE 33 Logging of security related events is addressed bySP.08.02 BR. NOTE 34 Logging and reporting of alarms and events is addressed bySP.08.03 BR.	ID02 section A.9	(ID01) 7.4.1.9 1. (ID01) 7.5 9.(1) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(9)[1]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.08.01RE(1)	The service provider shall have a process that can be performed for the asset owner to ensure the Automation Solution is configured to report security compromises that have been automatically detected through a communications interface that is accessible to the asset owner and that is commonly accepted by both the security and industrial automation communities.	ID02 section A.9	(ID01) 7.4.1.9 2. (ID01) 7.5 9.(2) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(9)[2]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.08.02BR	The service provider shall have a process that can be performed for the asset owner to ensure the Automation Solution is configured to write all security-related events, including user activities and account management activities, to an audit log that is kept for the number of days specified by the asset owner. NOTE 35 Logging and reporting of process-related events, such as setpoint changes and other operational/configuration data changes, is addressed by SP.08.03BR.	ID02 section A.9	(ID01) 7.4.1.9 3. (ID01) 7.5 9.(3) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(9)[3]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.08.02RE(1)	The service provider shall have a process that can be performed for the asset owner to ensure the Automation Solution is configured so that security-related data and event scan be accessed through one or more interfaces that is/are commonly accepted by both the security and industrial automation communities.	ID02 section A.9	(ID01) 7.4.1.9 3.(1) (ID01) 7.5 9.(3) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(9)[4]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.08.02RE(2)	The service provider shall have a process that can be performed for the asset owner to verify that security-related events can be written to an audit log.	ID02 section A.9	(ID01) 7.4.1.9 3.(2) (ID01) 7.5 9.(3) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(9)[5]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.08.03BR	The service provider shall have a process that can be performed for the asset owner to ensure the Automation Solution is configured to log and notify the operator of process-related events as required by the asset owner. The types of events include state changes/operating condition changes/configuration changes that can be due to manual or automated(those without human intervention)operation. NOTE 36 Logging of security related events is addressed bySP.08.02 BR.	ID02 section A.9	(ID01) 7.4.1.9 4. (ID01) 7.5 9.(4) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(9)[6]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.08.03RE(1)	The service provider shall have a process that can be performed for the asset owner to ensure the Automation Solution is configured to securely report alarms/alerts/events through an interface that is commonly accepted by both the security and industrial automation communities.	ID02 section A.9	(ID01) 7.4.1.9 4.(1) (ID01) 7.5 9.(4) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(9)[7]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.08.04BR	The service provider shall have a process that can be performed for the asset owner to provide documentation to the asset owner that describes the Automation Solution's ability to withstand the near-simultaneous occurrence of large numbers of events, typically referred to as event storms.	ID02 section A.9	(ID01) 7.4.1.9 5. (ID01) 7.5 9.(5) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(9)[8]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.09.01BR	The service provider shall have a process that can be performed for the asset owner to support the following: 1) the administration of a single, integrated data base, which maybe distributed or redundant, for defining and managing user and service accounts, 2) the creation of accounts for authorized users only, 3) the configuration for decentralized access to this database for the management of accounts, 4) administration of decentralized enforcement of the account settings (e.g. passwords, operating system privileges, and access control lists) defined in this data base.	ID02 section A.9	(ID01) 7.4.1.3 1. (ID01) 7.5 3.(1) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(3)[1]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.09.02BR	The service provider shall have a process that can be performed for the asset owner to create and maintain unique accounts for users.	ID02 section A.9	(ID01) 7.4.1.3 2. (ID01) 7.5 3.(2) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(3)[2]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.09.02RE(1)	The service provider shall have a process that can be performed for the asset owner to provide documentation to the asset owner that: 1) identifies all default user and service accounts that are installed in the Automation Solution, 2) describes the tools and procedures the asset owner can use to set/reset passwords for all default user and service accounts.	ID02 section A.9	(ID01) 7.4.1.3 2.(1) (ID01) 7.5 3.(2) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(3)[3]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)

ID	Requirement	Inputs	Measures	Verification steps	Outputs
SP.09.02RE(2)	The service provider shall have a process that can be performed for the asset owner to ensure that if an account/password is automatically generated for a user, other than operators and service groups, both the generated account and password are unique.	ID02 section A.9	(ID01) 7.4.1.3 2.(2) (ID01) 7.5 3.(2) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(3)[4]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.09.02RE(3)	The service provider shall have a process that can be performed for the asset owner to ensure that service, auto-login and operator accounts, and other accounts required for essential functions and/or continuous operations, or as required by the asset owner have been configured so that they never expire nor become disabled automatically.	ID02 section A.9	(ID01) 7.4.1.3 2.(3) (ID01) 7.5 3.(2) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(3)[5]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.09.02RE(4)	The service provider shall have a process that can be performed for the asset owner to ensure that the built-in administrator account is disabled, and if that is not possible, that it is renamed or otherwise made difficult to exploit.	ID02 section A.9	(ID01) 7.4.1.3 2.(4) (ID01) 7.5 3.(2) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(3)[6]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.09.03BR	The service provider shall have a process that can be performed for the asset owner to ensure that unused system default accounts have been removed or disabled.	ID02 section A.9	(ID01) 7.4.1.3 3. (ID01) 7.5 3.(3) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(3)[7]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.09.04BR	The service provider shall have a process that can be performed for the asset owner to ensure that all user accounts are removed once they are no longer needed. This includes: 1) temporary accounts under the control of the service provider, such as those used for integration or maintenance, 2) user accounts for service provider personnel who are no longer assigned to the Automation Solution (seeSP.01.07 BR for notifying the asset owner of the removal of service provider personnel from the Automation Solution.	ID02 section A.9	(ID01) 7.4.1.3 4. (ID01) 7.5 3.(4) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(3)[8]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.09.04RE(1)	The service provider shall have a process that can be performed for the asset owner to generate an audit log report after the completion of integration/maintenance activities that shows that accounts used to support these activities have been removed from the Automation Solution if they are no longer needed.	ID02 section A.9	(ID01) 7.4.1.3 4.(1) (ID01) 7.5 3.(4) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(3)[8]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.09.05BR	The service provider shall have a process that can be performed for the asset owner to configure password policies to achieve a minimum complexity commonly accepted by both the security and industrial automation communities. NOTE 40 At the time of writing, minimal password complexity is: 1) at least eight characters in length, and 2) a combination of at least three of the following four-character sets: lowercase, uppercase, numeric digit, and special characters(e.g.% and #).	ID02 section A.9	(ID01) 7.4.1.3 5. (ID01) 7.5 3.(5) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(3)[9]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.09.06BR	The service provider shall have a process that can be performed for the asset owner to configure passwords for local and system-wide(e.g. domain) user accounts to automatically expire after they have been in use for a period of time specified by the asset owner.	ID02 section A.9	(ID01) 7.4.1.3 6. (ID01) 7.5 3.(6) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(3)[10]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.09.06RE(1)	The service provider shall have a process that can be performed for the asset owner to configure password policies to prompt users to change passwords N days before they expire, where N is specified by the asset owner. This requirement does not apply to passwords that are not set to expire.	ID02 section A.9	(ID01) 7.4.1.3 6.(1) (ID01) 7.5 3.(6) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(3)[10]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.09.07BR	The service provider shall have a process that can be performed for the asset owner to ensure that default passwords are changed as required by the asset owner.	ID02 section A.9	(ID01) 7.4.1.3 7. (ID01) 7.5 3.(7) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(3)[11]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.09.08BR	The service provider shall have a process that can be performed for the asset owner to configure password policies to prevent users from reusing their last N passwords, where N is specified by the asset owner.	ID02 section A.9	(ID01) 7.4.1.3 8. (ID01) 7.5 3.(8) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(3)[12]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.09.08RE(1)	The service provider shall have a process that can be performed for the asset owner to configure password policies to prevent users from changing their passwords more frequently than once every N days, where N is specified by the asset owner.	ID02 section A.9	(ID01) 7.4.1.3 8.(1) (ID01) 7.5 3.(9) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(3)[12]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.09.09BR	The service provider shall have a process that can be performed for the asset owner to securely document and keep this documentation current for accounts whose passwords have been approved by the asset owner to be shared with the service provider.	ID02 section A.9	(ID01) 7.4.1.3 9. (ID01) 7.5 3.(10) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(3)[13]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.09.09RE(1)	The service provider shall have a process that can be performed for the asset owner to report to the asset owner passwords that were 1) shared and no longer need to be shared, 2) knowingly divulged, or 3) knowingly compromised, and to support the asset owner in changing passwords as necessary.	ID02 section A.9	(ID01) 7.4.1.3 9.(1) (ID01) 7.5 3.(10) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(3)[14]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)

ID	Requirement	Inputs	Measures	Verification steps	Outputs
SP.10.01BR	The service provider shall have a process that can be performed for the asset owner to provide the asset owner with documented instructions for the proper installation, configuration and update of malware protection mechanisms that are tested and verified for the Automation Solution.	ID02 section A.9	(ID01) 7.4.1.10 1. (ID01) 7.5 10.(1) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(10)[1]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.10.02BR	The service provider shall have a process that can be performed for the asset owner to ensure that: 1) malware protection mechanisms have been correctly installed/updated and properly configured in accordance with the service provider's approved procedures, as agreed with the asset owner, 2) malware definition files are installed within the time period agreed to with the asset owner, 3) malware configurations are maintained and kept current.	ID02 section A.9	(ID01) 7.4.1.10 2. (ID01) 7.5 10.(2) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(10)[2]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.10.02RE(1)	The service provider shall have a process that can be performed for the asset owner to create and maintain the documentation that describes the use of malware protection mechanisms in the Automation Solution for which the service provider is responsible. This documentation shall include for each component used in the Automation Solution: 1) the installation state of malware protection mechanisms or a statement that it is not technically possible to install malware protection mechanisms on the component, 2) the current configuration settings of the installed malware protection mechanism, 3) the current status of malware definition files approved for installation on the component, 4) the use of other mitigating features and functions used to reduce the risk of infection and/or mitigate the effect of infections(e.g. isolating infections, reporting infections)	ID02 section A.9	(ID01) 7.4.1.10 2.(1) (ID01) 7.5 10.(2) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(10)[3]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.10.03BR	The service provider shall have a process that can be performed for the asset owner to verify, at asset owner request, that malware, other than zero-day malware, can be detected and properly handled by the installed malware protection mechanisms.	ID02 section A.9	(ID01) 7.4.1.10 3. (ID01) 7.5 10.(3) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(10)[4]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.10.04BR	The service provider shall have a process that can be performed for the asset owner to provide to the asset owner documentation that describes: 1) how malware definition files for the Automation Solution are evaluated and approved, 2) reporting the status of malware definition files to the asset owner within N days after release of the files by the manufacturer, where N has been agreed to by the service provider and asset owner. This status includes the applicability (e.g. component and version) and approval state (e.g. approved, installed, disapproved, etc.) for each malware definition file.	ID02 section A.9	(ID01) 7.4.1.10 4. (ID01) 7.5 10.(4) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(10)[5]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.10.05BR	The service provider shall have a process that can be performed for the asset owner to ensure that all components, including workstations, supplied to the Automation Solution by the service provider are free of known malware prior to use in the Automation Solution.	ID02 section A.9	(ID01) 7.4.1.10 5. (ID01) 7.5 10.(5) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(10)[6]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.10.05RE(1)	The service provider shall have a process that can be performed for the asset owner to verify that, for portable media that it uses for system testing, commissioning, and/or maintenance, it uses this portable media for this purpose only.	ID02 section A.9	(ID01) 7.4.1.10 5.(1) (ID01) 7.5 10.(5) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(10)[7]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.10.05RE(2)	The service provider shall have a process that can be performed for the asset owner to ensure that all portable media used in or connected to the Automation Solution by the service provider is free of known malware prior to use in the Automation Solution.	ID02 section A.9	(ID01) 7.4.1.10 5.(2) (ID01) 7.5 10.(5) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(10)[8]	ID02 Table C.6 ID02 Table C.7	ID07_Dummy Project - Security Policies and Procedures Plan (defined in ID02 section A.4) ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.11.01BR	The service provider shall have a process that can be performed for the asset owner to provide documentation to the asset owner that describes how security patches for Automation Solution software for which it is responsible are evaluated and approved. NOTE 43 In this document, firmware upgrades are regarded as software patches. NOTE 44 In this document, patch installation refers to installation of patches to the Automation Solution.	ID02 section A.9	(ID01) 7.4.1.11 2. (ID01) 7.5 11.(1) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(11)[1]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.11.01RE(1)	The service provider shall have a process that can be performed for the asset owner to review, as a result of changes in security risks, how it evaluates and approves security patches for Automation Solution software for which it is responsible.	ID02 section A.9	(ID01) 7.4.1.11 2.(1) (ID01) 7.5 11.(1) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(11)[2]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.11.02BR	The service provider shall have a process that can be performed for the asset owner to make documentation available to the asset owner that describes security patches/updates. The process shall include making the description of each patch available to the asset owner within a time frame after the release of a patch by its manufacturer that is acceptable to the asset owner. The documentation shall include:	ID02 section A.9	(ID01) 7.4.1.11 3. (ID01) 7.5 11.(2) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(11)[3]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)

ID	Requirement	Inputs	Measures	Verification steps	Outputs
	1) security patches that are applicable to components of the Automation Solution for which the service provider is responsible, 2) the approval status/lifecycle state(see IEC TR 62443-2-3) of each, i.e., approved, not approved, not applicable, in test, 3) a warning if the application of an approved patch requires or causes a re-start of the system, 4) the reason for those that are not approved or not applicable, 5) a plan for the remediation for those that are applicable but not approved.				
SP.11.02RE(1)	The service provider shall have a process that can be performed for the asset owner to make available to the asset owner, through an interface commonly accepted by the industrial and security communities, a patch list that identifies: 1) approved security patches applicable to Automation Solution software for which the service provider is responsible (e.g. control system and component software, operating system software, and 3rd party software applications), 2) which of the applicable security patches have been approved for use in the Automation Solution, 3) the version numbers of the software to which the approved patches apply. This list shall be available to the asset owner within an agreed timeframe after the release of a patch by the manufacturer.	ID02 section A.9	(ID01) 7.4.1.11 3.(1) (ID01) 7.5 11.(2) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(11)[4]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.11.02RE(2)	The service provider shall have a process that can be performed for the asset owner to: 1) recommend a mitigation plan when requested by the asset owner for security patches that were applicable and approved by the service provider, but that were not approved by the asset owner, for example, because they could impact operations or performance (see SP 11.05 BR), 2) implement the mitigation plan after approval by the asset owner.	ID02 section A.9	(ID01) 7.4.1.11 3.(2) (ID01) 7.5 11.(1) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(11)[5]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.11.03BR	The service provider shall have a process that can be performed for the asset owner for the provider's management of patches that provides for: 1) patches to be obtained by the asset owner directly from the manufacturer of the patch, and/or 2) redistribution of patches by the service provider only if approved by the asset owner and permitted by the manufacturer of the patch.	ID02 section A.9	(ID01) 7.4.1.11 4. (ID01) 7.5 11.(3) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(11)[6]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.11.04BR	The service provider shall have a process that can be performed for the asset owner to provide documentation to the asset owner that describes how to perform patching both manually and via a patch management server and how to obtain patching status reports. 1) When using a patch management server, documentation shall be provided to show how to use the server to install patches. 2) For manual patching using portable media, documentation shall be provided that describes how to install patches from the media.	ID02 section A.9	(ID01) 7.4.1.11 5. (ID01) 7.5 11.(4) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(11)[7]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.11.05BR	The service provider shall have a process that can be performed for the asset owner to obtain approval from the asset owner for installing each and every security patch.	ID02 section A.9	(ID01) 7.4.1.11 6. (ID01) 7.5 11.(5) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(11)[8]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.11.06BR	The service provider shall have a process that can be performed for the asset owner to ensure that, if the asset owner requests the service provider to install security software patches (including firmware upgrades), the service provider installs them at a time specified by the asset owner.	ID02 section A.9	(ID01) 7.4.1.11 7. (ID01) 7.5 11.(6) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(11)[9]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.11.06RE(1)	The service provider shall have a process that can be performed for the asset owner to ensure that the security hardening level of the Automation Solution is retained after patch installation.	ID02 section A.9	(ID01) 7.4.1.11 7.(1) (ID01) 7.5 11.(6) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(11)[10]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.11.06RE(2)	The service provider shall have a process that can be performed for the asset owner to ensure that, for devices that support installation of software/firmware over the network, the update process ensures the authenticity and integrity of the device software/firmware.	ID02 section A.9	(ID01) 7.4.1.11 7.(2) (ID01) 7.5 11.(6) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(11)[11]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.11.06RE(3)	The service provider shall have a process that can be performed for the asset owner to determine the installation status of all security patches applicable to the Automation Solution for which the service provider is responsible.	ID02 section A.9	(ID01) 7.4.1.11 7.(3) (ID01) 7.5 11.(6) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(11)[12]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.12.01BR	The service provider shall have a process that can be performed for the asset owner to provide documentation for recommended backup procedures for the Automation Solution that includes, but is not limited to the following: 1) Instructions on how to make a full backup of the Automation Solution, and partial backups, if applicable, using at least one of the following methods: a) proprietary backup architecture on portable media, b) single system backup architecture on portable media, c) distributed backup architecture in which each backup system backs up a subset of the service provider's Automation Solutions at the asset owner's site, or d) centralized backup architecture using one backup system for all of the	ID02 section A.4 ID02 section A.9	(ID01) 7.4.1.12 1. (ID01) 7.5 12.(1) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(12)[1]	ID02 Table C.6 ID02 Table C.7	ID07_Dummy Project - Security Policies and Procedures Plan (defined in ID02 section A.4) ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)

ID	Requirement	Inputs	Measures	Verification steps	Outputs
	service provider's Automation Solutions at the asset owner's site. 2) Provisions to back up the following types of data: a) operation system files and cryptographic data (e.g. keying material), b) applications (including middleware, such as tunnelling software), c) configuration data, data base files, d) log files, electronic log book, e) unconventional file types including, but not limited to, network equipment settings, control system controller settings (tuning parameters, set points, alarm levels), f) field instrumentation parameters, g) directory information, h) other files identified by the service provider that are required to create a complete backup of the Automation Solution. 3) Recommendations for offsite storage of backup media. 4) Provisions to ensure changes to the Automation Solution that could affect the integrity of a backup are not made while a backup is in progress. NOTE 46 Examples of partial restores include operating system, application software, databases, and configuration files.				
SP.12.02BR	The service provider shall have a process that can be performed for the asset owner to provide documented instructions to the asset owner for restoring the Automation Solution or its components to normal operation.	ID02 section A.4 ID02 section A.9	(ID01) 7.4.1.12 2. (ID01) 7.5 12.(2) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(12)[2]	ID02 Table C.6 ID02 Table C.7	ID07_Dummy Project - Security Policies and Procedures Plan (defined in ID02 section A.4) ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.12.03BR	The service provider shall have a process that can be performed for the asset owner to provide documentation to the asset owner that describes how to control and securely manage portable backup media.	ID02 section A.4 ID02 section A.9	(ID01) 7.4.1.12 3. (ID01) 7.5 12.(3) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(12)[3]	ID02 Table C.6 ID02 Table C.7	ID07_Dummy Project - Security Policies and Procedures Plan (defined in ID02 section A.4) ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.12.04BR	The service provider shall have a process that can be performed for the asset owner to provide documentation to the asset owner that describes how to verify successful system backup.	ID02 section A.4 ID02 section A.9	(ID01) 7.4.1.12 4. (ID01) 7.5 12.(4) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(12)[4]	ID02 Table C.6 ID02 Table C.7	ID07_Dummy Project - Security Policies and Procedures Plan (defined in ID02 section A.4) ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.12.05BR	The service provider shall have a process that can be performed for the asset owner to demonstrate that: 1) it is possible to perform a complete backup of the Automation Solution, and 2) it is possible to restore a fully functioning Automation Solution from this backup.	ID02 section A.9	(ID01) 7.4.1.12 5. (ID01) 7.5 12.(5) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(12)[5]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.12.06BR	The service provider shall have a process that can be performed for the asset owner to perform a backup of the Automation Solution in accordance with the asset owner's backup schedules and data restore and disaster recovery objectives.	ID02 section A.9	(ID01) 7.4.1.12 6. (ID01) 7.5 12.(6) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(12)[6]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.12.07BR	The service provider shall have a process that can be performed for the asset owner to demonstrate that the Automation Solution is able to continue normal operation during a backup.	ID02 section A.9	(ID01) 7.4.1.12 7. (ID01) 7.5 12.(7) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(12)[7]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.12.08BR	The service provider shall have a process that can be performed for the asset owner to provide documentation to the asset owner that describes how to generate and maintain audit logs of all backup and restore activities.	ID02 section A.9	(ID01) 7.4.1.12 8. (ID01) 7.5 12.(8) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(12)[8]	ID02 Table C.6 ID02 Table C.7	ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)
SP.12.09BR	The service provider shall have a process that can be performed for the asset owner to document a recommended disaster recovery plan that includes, but is not limited to, the following: 1) description of various disaster scenarios and their impact on the Automation Solution, 2) step-by-step instructions for restoring, restarting failed components and integrating them into the Automation Solution, 3) minimum architecture requirement for restoring the entire Automation Solution.	ID02 section A.4 ID02 section A.9	(ID01) 7.4.1.12 9. (ID01) 7.5 12.(9) (ID01) 7.6.1 1.(3) (ID01) 7.6.1 2.(12)[9]	ID02 Table C.6 ID02 Table C.7	ID07_Dummy Project - Security Policies and Procedures Plan (defined in ID02 section A.4) ID12_Dummy Project - Security Functional Description Specifications (O&M Manual) (defined in ID02 section A.9)

B.5 CHANGE REQUEST FORM

The following table is for change request when the configuration item need to be updated. For each configuration object, it should use related checklist to verify the change.

CHANGE REQUEST FORM

Change Description		
Project Name:	**Change Name:**	**Number:**
Requested By:	**Contact:**	**Date:**
Description of Change:		
Reason for Change:		
Priority [Circle One]: 1. High 2. Medium 3. Low		
Impact on Deliverables:		
Impact of Not Responding to Change (and Reason Why):		
Date Needed:	**Approval of Request:**	**Date:**

Change Impact
Tasks/Scope Affected:
Cost Evaluation:
Risk Evaluation:
Quality Evaluation:
Additional Resources:
Duration:

Additional Effort:
Impact on Deadline:
Alternative and Recommendations:
Comments:

Sign Offs	
[Circle One]: 1. Accepted 2. Deferred 3. Rejected 4. More Info Requested	
Comments:	
Project Manager Signature:	**Date:**
Decision Maker Signature:	**Date:**

Annexes C: Security Verification Checklist for Security Implementation

The purpose of Annexes C is to perform the security verification for each security implementation for SuC. The implementations to be verified include:

C.1 Security Plan Verification Checklist.

C.2 Threat and Preliminary Risk Assessment (TRA) Verification Checklist.

C.3 Network architecture documentation Verification Checklist.

C.4 Inventory Asset List Verification Checklist.

C.5 Critical Security Design Verification Checklist.

C.6 Documents of System Security Countermeasures Verification Checklist.

C.7 System Security Acceptance Testing Verification Checklist.

C.8 Operation and Support/Maintenance Verification Checklist.

C.1 The Security Plan Checklist

To verify the Security Plan (including the Security Management Plan, Vendor Management Plan, and SI/SM Project Security Management Plan) documents.

Table C.1 Security Plan Verification Checklist.

Security Plan Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
VCSP.01	Security Management Plan: include Key Security Roles.	□Not Applicable □Checked □Not Compliant	□	□			
VCSP.02	Security Management Plan: include the asset owner's security requirements, policies, and procedures.	□Not Applicable □Checked □Not Compliant	□	□			
VCSP.03	Security Management Plan: include the PE/O's Management of Change (MoC) and Permit to Work (PtW) processes.	□Not Applicable □Checked □Not Compliant	□	□			
VCSP.04	Security Management Plan: include the protection of the confidentiality of the asset owner's data.	□Not Applicable □Checked □Not Compliant	□	□			
VCSP.05	Security Management Plan: include High Level Security Schedule.	□Not Applicable □Checked □Not Compliant	□	□			
VCSP.06	Security Management Plan: include Cybersecurity Governance, Timeline, and Testing.	□Not Applicable □Checked □Not Compliant	□	□			
VCSP.07	Security Vendor Management Plan: include the asset owner's	□Not Applicable □Checked	□	□			

Security Plan Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	security requirements, policies, and procedures.	□Not Compliant					
VCSP.08	Security Vendor Management Plan: include the PE/O's Management of Change (MoC) and Permit to Work (PtW) processes.	□Not Applicable □Checked □Not Compliant	□	□			
VCSP.08-1	Security Vendor Management Plan: include the protection of the confidentiality of the asset owner's data.	□Not Applicable □Checked □Not Compliant	□	□			
VCSP.09	Security Policies and Procedures Management Plan: include Account Management Plan.	□Not Applicable □Checked □Not Compliant	□	□			
VCSP.10	Security Policies and Procedures Management Plan: include Vulnerability Management Procedure with the recommendation of security analysis tools to use.	□Not Applicable □Checked □Not Compliant	□	□			
VCSP.11	Security Policies and Procedures Management Plan: include Vulnerability Management Procedure with Vulnerability handling process.	□Not Applicable □Checked □Not Compliant	□	□			

Security Plan Verification Checklist

Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
VCSP.12	Security Policies and Procedures Management Plan: include Backup and Restore Procedure.	□Not Applicable □Checked □Not Compliant	□	□			
VCSP.13	Security Policies and Procedures Management Plan: include System Malware Protection Procedure.	□Not Applicable □Checked □Not Compliant	□	□			
VCSP.14	Security Policies and Procedures Management Plan: include Change and Patch Management Procedure.	□Not Applicable □Checked □Not Compliant	□	□			
VCSP.15	Security Policies and Procedures Management Plan: include Logging, Monitoring, and Reporting Procedure.	□Not Applicable □Checked □Not Compliant	□	□			
VCSP.16	SI/SM Project Security Management Plan: include all assigned personnel (including subcontractor or consultant) have successfully passed security-related background checks.(May need to check with personnel QP-02-01: 基本資料表/個人訓練履歷表 records).	□Not Applicable □Checked □Not Compliant	□	□			

Security Plan Verification Checklist

Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
VCSP.17	SI/SM Project Security Management Plan: include assign a security contact which is responsible and accountable for activities.	□Not Applicable □Checked □Not Compliant	□	□			
VCSP.18	SI/SM Project Security Management Plan: include the documented minimum SuC's cyber-security qualifications for security lead positions and the capability to assign security leads to Automation Solutions who meet these qualifications and are qualified for this role	□Not Applicable □Checked □Not Compliant	□	□			
VCSP.19	SI/SM Project Security Management Plan: include that inform the PE/O of personnel changes.	□Not Applicable □Checked □Not Compliant	□	□			
VCSP.20	Training Records	□Not Applicable □Checked □Not Compliant	□	□			
VCSP.21	SI/SM Project Security Management Plan: include the asset owner's security	□Not Applicable □Checked □Not Compliant	□	□			

Security Plan Verification Checklist

Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	requirements, policies, and procedures.						
VCSP.22	SI/SM Project Security Management Plan: include the PE/O's Management of Change (MoC) and Permit to Work (PtW) processes.	□Not Applicable □Checked □Not Compliant	□	□			
VCSP.23	SI/SM Project Security Management Plan: include the protection of the confidentiality of the asset owner's data.	□Not Applicable □Checked □Not Compliant	□	□			
VCSP.24	Check the training record of involve personnel (including subcontractor or consultant) have passed the training activity for Security Planand, and the personnel signature in SI/SM Project Security Management Plan cover page that agree with project requirements.	□Not Applicable □Checked □Not Compliant	□	□			

C.2 Threat and Preliminary Risk Assessment (TRA) Verification Checklist

To verify the Threat and Preliminary Risk Assessment (TRA) documents.

Table C.2 Threat and Preliminary Risk Assessment (TRA) Verification Checklist.

Threat and Preliminary Risk Assessment (TRA) Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
VCRA.01	TRA report include SUC description.	□Not Applicable □Checked □Not Compliant	□	□			
VCRA.02	TRA report include Zone and conduit drawings.	□Not Applicable □Checked □Not Compliant	□	□			
VCRA.03	TRA report include Zone and conduit characteristics.	□Not Applicable □Checked □Not Compliant	□	□			
VCRA.04	TRA report include Operating environment assumptions.	□Not Applicable □Checked □Not Compliant	□	□			
VCRA.05	TRA report include Threat Description, and include data threat in transit and/or at rest.	□Not Applicable □Checked □Not Compliant	□	□			
VCRA.06	TRA report include countermeasures of Organizational security policies (security controls, policies & procedures), and include data	□Not Applicable □Checked □Not Compliant	□	□			

Threat and Preliminary Risk Assessment (TRA) Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	protection in transit and/or at rest.						
VCRA.07	TRA report include countermeasures of Cybersecurity Requirements Specifications for Assets, and include data protection in transit and/or at rest.	□Not Applicable □Checked □Not Compliant	□	□			
VCRA.08	TRA report include Tolerable risk.	□Not Applicable □Checked □Not Compliant	□	□			
VCRA.09	TRA report include Regulatory requirements.	□Not Applicable □Checked □Not Compliant	□	□			

C.3 Network Architecture Documentation Verification Checklist

To verify the Network Architecture Documents.

Table C.3 Network Architecture Documentation Verification Checklist.

Network Architecture Documentation Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
VCNW.01	The Diagram provide the network architecture that include each network segment, the network devices, including application gateways, used to interconnect the network segments, and identification of all network interfaces internal to the Automation Solution and those that connect the Automation Solution to external networks.	□Not Applicable □Checked □Not Compliant	□	□			
VCNW.02	The Data Flow Diagram provide Function description for each host.	□Not Applicable □Checked □Not Compliant	□	□			
VCNW.03	The Data Flow Diagram provide Interfaces, ports of devices.	□Not Applicable □Checked □Not Compliant	□	□			
VCNW.04	The Data Flow Diagram provide Each data flow shows in one-direction.	□Not Applicable □Checked □Not Compliant	□	□			

Network Architecture Documentation Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
VCNW.05	The Data Flow Diagram provide Protocols of each data flow direction.	□Not Applicable □Checked □Not Compliant	□	□			
VCNW.06	The Data Flow Diagram provide short function description for each data flow direction.	□Not Applicable □Checked □Not Compliant	□	□			
VCNW.07	The Data Flow Diagram include wired and wireless devices used for control and instrumentation have been registered with the correct values.	□Not Applicable □Checked □Not Compliant	□	□			

C.4 Inventory Asset List Verification Checklist

To verify the Inventory Asset List Documents.

Table C.4 Inventory Asset List Verification Checklist.

Inventory Asset List Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
VCAL.01	Include hardware and software asset identification list.	□Not Applicable □Checked □Not Compliant	□	□			
VCAL.02	Include version and serial numbers, of all devices and their software components in the SuC	□Not Applicable □Checked □Not Compliant	□	□			
VCAL.03	Include contents of Basic Sheet for Inventory List	□Not Applicable □Checked □Not Compliant	□	□			
VCAL.04	Include contents of Security Sheet for Risk Assessment of (1) Unique identifier (2) Name (3) Model/version (4) Supplier/ Contractor/ Fabricator (5) Services running (6) Software and applications (7) Patch status	□Not Applicable □Checked □Not Compliant	□	□			

Inventory Asset List Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	(8) Anti-virus status (9) IP & MAC addresses (10) Network segment (11) Hypervisors (12) OS/Firmware version (13) Security software installed (type and version) (14) Open Ports (15) Protocols						
VCAL.05	Include wired and wireless devices used for control and instrumentation have been registered with the correct values.	□Not Applicable □Checked □Not Compliant	□	□			

C.5 Critical Security Design Verification Checklist

To verify the Critical Security Design Documents.

Table C.5 Critical Security Design Verification Checklist.

Critical Security Design Verification Checklist

Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
VCSD.01	Preliminary security risk assessment is performed.	□Not Applicable □Checked □Not Compliant	□	□			
VCSD.02	The risk parameters is to obtained.	□Not Applicable □Checked □Not Compliant	□	□			
VCSD.03	The security architecture reviews and/or security assessment and/or threat analysis of the control system used in the SuCs have been conducted by a third party.	□Not Applicable □Checked □Not Compliant	□	□			
VCSD.04	TRA report is generated and reviewed.	□Not Applicable □Checked □Not Compliant	□	□			
VCSD.05	Detailed risk assessment is performed.	□Not Applicable □Checked □Not Compliant	□	□			
VCSD.06	Asset Inventory List is generated and reviewed.	□Not Applicable □Checked □Not Compliant	□	□			
VCSD.07	Review the network segments of the SuC and their interfaces to other segments, including external networks, and for each	□Not Applicable □Checked □Not Compliant	□	□			

Critical Security Design Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	interface designate whether it is trusted or untrusted.						
VCSD.08	Assess the interfaces of the SuC that have been identified as untrusted are protected by network security devices or equivalent mechanisms, with documented and maintained security rules.	□Not Applicable □Checked □Not Compliant	□	□			
VCSD.09	Review 1) data storage points and data flows within the SuC that require safeguarding, and 2) the security requirements for their safeguarding (e.g. confidentiality, integrity, availability)	□Not Applicable □Checked □Not Compliant	□	□			
VCSD.10	Verify the access controls of the SuC shall be configured to protect data within the SuC requiring safeguarding, from unauthorized disclosure or modification, whether at rest or in transit.	□Not Applicable □Checked □Not Compliant	□	□			
VCSD.11	Assess wireless systems current in its description.	□Not Applicable □Checked	□	□			

Critical Security Design Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
		□Not Compliant					
VCSD.12	If a wireless communication equipment is used, verify 1) is registered in Asset Inventory List, 2) − An unique, Automation Solution-specific identifiers used for wireless networks are descriptive, 3) wireless device addresses are configured.	□Not Applicable □Checked □Not Compliant	□	□			
VCSD.13	Review security architecture and the communications of the SIS used in the SuC are conducted and addressed.	□Not Applicable □Checked □Not Compliant	□	□			
VCSD.14	Review Security Risk Mitigation Plan and Security Countermeasures	□Not Applicable □Checked □Not Compliant	□	□			
VCSD.15	Review Cybersecurity Function Requirement Specifications	□Not Applicable □Checked □Not Compliant	□	□			

C.6 Documents of System Security Countermeasures Verification Checklist

To verify the Implement Documents of System Security Countermeasures.

Table C.6 Documents of System Security Countermeasures Verification Checklist.

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
Asset Management							
VCSC.01	(1) Asset Baselining Description include: A. The version and serial numbers, of all devices and their software components in the SuC. B. Characteristics of The Inventory Asset List, e.g. Device Name-ID, Device Description-Purpose, Device Category, Device SL-T, Zone, Plant Area Association, Physical Location, Connection, Permanent /Temporary, Manufacturer Name, Manufacturer Model, Real Time Operating System (OS), Bios/Firmware, etc.	□Not Applicable □Checked □Not Compliant	□	□			

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	(7.2.1-2)						
VCSC.02	(2) Asset Inventory Management Description include: A. Assign a security reviewer to check the validity of security content, their ability to be verified. B. The network architecture documentation and Inventory Asset List shall be verified that wired and wireless devices used for control and instrumentation have been registered with the correct values to approve. (7.2.2.-2. & 3)	□Not Applicable □Checked □Not Compliant	□	□			
VCSP.03	(3) Secure Time Authentication and Synchronization Description include: A. A secure and accurate source	□Not Applicable □Checked □Not Compliant	□	□			

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	B. A protocol that is commonly accepted by both the security and industrial automation communities (7.4.1.2-2)						
Endpoint Security							
VCSC.04	(1) Malicious Code Prevention Description□						
VCSC.04-01	A. Documented instructions for the proper installation, configuration, and update of malware protection mechanisms shall be provided for the PE/O. (7.4.1.10-1)	□Not Applicable □Checked □Not Compliant					
VCSC.04-02	B. Ensured that: a. malware protection mechanisms have been correctly installed/updated and properly configured in accordance with the service provider's approved procedures, as agreed with the PE/O	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	b. malware definition files are installed within the time period agreed to with the PE/O c. malware configurations are maintained and kept current (7.4.1.10-2)						
VCSC.04-03	C. Malware protection mechanisms shall include: a. the installation state or a statement that it is not technically possible to install malware protection mechanisms, b. the current configuration settings, c. the current status, d. the use of other mitigating features and functions used to reduce the risk of infection and/or mitigate the effect of infections (7.4.1.10-2.(1))	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
VCSC.04-04	D. Malware, other than zero-day malware, should be detected and properly handled by the installed malware protection mechanisms. Infected files could be detected and subsequently quarantined/deleted by the anti-malware product. (7.4.1.10-3)	□Not Applicable □Checked □Not Compliant					
VCSC.04-05	E. Malware definition files should describe: a. how malware definition files are evaluated and approved, b. reporting the status of malware definition files. (7.4.1.10-4)	□Not Applicable □Checked □Not Compliant					
VCSC.04-06	F. Ensure that devices with detectable infections are not installed in the Automation Solution (7.4.1.10-5)	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
VCSC.04-07	G. Ensure that, for portable media that it uses for system testing, commissioning, and/or maintenance, it uses this portable media for this purpose only.(7.4.1.10-5.(1))	□Not Applicable □Checked □Not Compliant					
VCSC.04-08	H. Ensure that all portable media used in or connected to the Automation Solution by the service provider is free of known malware prior to use in the Automation Solution. (7.4.1.10-5.(2))	□Not Applicable □Checked □Not Compliant					
VCSC.05	(2) End Point Protection and Management Description relates to reduce the attack surface of SuC, include: A. unnecessary software applications and services and their associated communication access	□Not Applicable □Checked □Not Compliant	□	□			

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	points are disabled and/or removed, B. network addresses in use are authorized, C. physical and logical access to diagnostic and configuration ports is protected from unauthorized access and use, D. unused ports on network devices are configured to prevent unauthorized access, E. maintenance processes maintain the hardened state of the SuC during its lifetime. (7.4.1.2-3)						
VCSC.05-01	Check the description of the retention capabilities that provided by the Automation Solution for storing/archiving sensitive data, includes capacities, pruning and purging	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	functions, retention timeouts, etc. (7.4.1.2-10(2))						
VCSC.05-02	Check the description of permanently destroy/delete all data in the component requiring safeguarding, as described in SP 03.10 BR, when it removes that component from the Automation Solution. (7.4.1.2-10(4))	□Not Applicable □Checked □Not Compliant					
VCSC.05-03	Check the description of data storage points and data flows within the automation solution that require safeguarding, including the security requirements for their safeguarding (e.g. confidentiality, integrity) (maybe refer to the approved TRA report) (7.4.1.2-10)	□Not Applicable □Checked □Not Compliant					
VCSC.05-04	Check the description of mechanisms for configuring and verifying the automation solution or reference architecture to protect	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	confidentiality and integrity of data requiring safeguard (maybe refer to the approved TRA report) (7.4.1.2-10(1))						
VCSC.05-05	Verify check that sensitive data in devices / components that are removed from the automation solution and permanently destroyed.(6.5.3.2)	□Not Applicable □Checked □Not Compliant					
Hardening Control							
VCSC.06	(1) Application and User Hardening Management Description relates to reduce the attack surface of SuC, include: A. unnecessary software applications and services and their associated communication access points are disabled and/or removed, B. network addresses in use are authorized,	□Not Applicable □Checked □Not Compliant	□	□			

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	C. physical and logical access to diagnostic and configuration ports is protected from unauthorized access and use, D. unused ports on network devices are configured to prevent unauthorized access, E. maintenance processes maintain the hardened state of the SuC during its lifetime. (7.4.1.2-3)						
VCSC.06-01	Description of Certificate Authority Management, and Verify/check that only necessary, authorized, and documented Certificate Authority (CA) digital certificates are installed. (7.4.1.2-4)	□Not Applicable □Checked □Not Compliant					
Identity and Access Management (IAM)							
VCSC.07	(1) Use Control and Least Functionality Settings Description						

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
VCSC.07-01	A. It shall configure the use of least privilege for the administration of network devices for which the Project is responsible. (7.4.1.2-8)	□Not Applicable □Checked □Not Compliant					
VCSC.07-02	B. It shall configure network device access controls, including those for wireless network devices, and role-based access control, as required by the PE/O or the Security Policies and Procedures Management Plan. (7.4.1.2-8 (1))	□Not Applicable □Checked □Not Compliant					
VCSC.07-03	C. It shall apply security measures to protect the confidentiality and integrity of data that is used in the administration of communication devices and that is identified as sensitive data requiring safeguarding (e.g.	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	cryptographic mechanisms) (7.4.1.2-8 (2))						
VCSC.07-04	D. A mutual authentication shall be used for the administration of communication devices as required by the PE/O or the Security Policies and Procedures Management Plan. (7.4.1.2-8 (3))	□Not Applicable □Checked □Not Compliant					
VCSC.08	(2) Internal and External User Access Controls Description						
VCSC.08-01	A. All remote access applications used in the Automation Solution shall be commonly accepted by both the security and industrial automation communities. (7.4.1.8-1)	□Not Applicable □Checked □Not Compliant					
VCSC.08-02	B. The detailed instructions for the installation, configuration, operation, and termination of the	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	remote access applications to be used in the Automation Solution. (7.4.1.8-2)						
VCSC.08-03	C. The information about all proposed remote access connections to the PE/O that includes, for each connection: a. its purpose, b. the remote access application to be used, c. how the connection will be established, d. the location and identity of the remote client. (7.4.1.8-3)	□Not Applicable □Checked □Not Compliant					
VCSC.08-04	D. All remote access connections to the Automation Solution shall be authorized by the PE/O. The requirements for remote access connections should be	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	generated by a risk assessment. (7.4.1.8-4)						
VCSC.08-05	E. All remote access connections conducted over the Internet or over other publicly accessible media that are used to support remote access to the Automation Solution by the Project shall be protected. (7.4.1.8-5)	□Not Applicable □Checked □Not Compliant					
VCSC.09	(3) Network Access Controls Description						
VCSC.09-01	A. A physical network segmentation architecture shall be implemented according to the approved network and data flow diagram by the PE/O. (7.4.1.2-1)	□Not Applicable □Checked □Not Compliant					
VCSC.09-02	B. Identify and document the network segments of the SuC and their interfaces to other segments and for	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	each interface designate whether it is trusted or untrusted. (7.3.1.1-4. (1))						
VCSC.09-03	C. Assess the interfaces of the SuC that have been identified as untrusted and are protected by network security devices or equivalent mechanisms, with documented and maintained security rules. At a minimum, the following shall be protected: a. External interfaces b. Level 2/Level 3 interfaces c. Interfaces between the BPCS and the SIS d. Interfaces connecting wired and wireless BPCS networks e. Interfaces connecting the BPCS to data warehouses (7.3.1.1-4. (2))	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
VCSC.09-04	D. The protection mechanisms of the interfaces of the SuC shall be documented, and their effectiveness shall be ensured. (7.3.1.1-4. (3))	□Not Applicable □Checked □Not Compliant					
VCSC.09-05	E. All remote access applications used in the Automation Solution shall be commonly accepted by both the security and industrial automation communities. (7.4.1.8-1)	□Not Applicable □Checked □Not Compliant					
VCSC.09-06	F. The detailed instructions for the installation, configuration, operation, and termination of the remote access applications to be used in the Automation Solution. (7.4.1.8-2)	□Not Applicable □Checked □Not Compliant					
VCSC.09-07	G. The information about all proposed remote access	□Not Applicable □Checked					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	connections to the PE/O that includes, for each connection: a. its purpose, b. the remote access application to be used, c. how the connection will be established, d. the location and identity of the remote client. (7.4.1.8-3)	□Not Compliant					
VCSC.09-08	H. All remote access connections to the Automation Solution shall be authorized by the PE/O. The requirements for remote access connections should be generated by a risk assessment. (7.4.1.8-4)	□Not Applicable □Checked □Not Compliant					
VCSC.09-09	I. All remote access connections conducted over the Internet or over other publicly accessible	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	media that are used to support remote access to the Automation Solution by the Project shall be protected. (7.4.1.8-5)						
VCSC.09-10	For Perform security review of Maintenous : Any changes do not negatively impact the approved network segmentation. (6.5.2.1-4)	□Not Applicable □Checked □Not Compliant					
VCSC.10	(4) Application Access Controls Description relates to that access is granted only to resources that are needed, and operating system privileges are similarly restricted to only those that are needed. It shall configure network device access controls as required by the PE/O or the Security Policies and Procedures Management Plan. (7.4.1.2-8., 7.4.1.2-8. (1))	□Not Applicable □Checked □Not Compliant	□	□			

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
VCSC.11	(5) User Access Rights and Role-based Access Controls Description relates to that access is granted only to resources that are needed, and operating system privileges are similarly restricted to only those that are needed. It shall configure network device access controls as required by the PE/O or the Security Policies and Procedures Management Plan. (7.4.1.2-8., 7.4.1.2-8. (1))	□Not Applicable □Checked □Not Compliant	□	□			
VCSC.12	(6) Access and Administration Mechanisms Description						
VCSC.12-01	A. An account management system should be provided to support the following: a. the administration of a single, integrated database, b. the creation of accounts for authorized users only,	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	c. the configuration for decentralized access to this database for the management of accounts, d. administration of decentralized enforcement of the account settings defined in this database. (7.4.1.3.-1)						
VCSC.12-02	B. The account management shall provide to create and maintain unique accounts for each Automation Solution user. It should prevent users from having to share accounts, i.e. by having a separate account. (7.4.1.3.-2)	□Not Applicable □Checked □Not Compliant					
VCSC.12-03	C. An account management document should be provided to the PE/O that: a. identifies all default user and service accounts that are installed in the Automation Solution,	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	b. describes the tools and procedures the PE/O can use to set/reset passwords for all default user and service accounts. (7.4.1.3.-2. (1) (SP.09.02 RE (1)))						
VCSC.12-04	D. The built-in administrator account should be disabled, and if that is not possible, that it should be renamed or otherwise made difficult to exploit. (7.4.1.3.-2. (4))	□Not Applicable □Checked □Not Compliant					
VCSC.12-05	E. Unused system default accounts should be removed or disabled. (7.4.1.3.-3)	□Not Applicable □Checked □Not Compliant					
VCSC.12-06	F. All user accounts should be removed once they are no longer needed, including a. temporary accounts under the control of the Project,	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	b. user accounts for the Project personnel who are no longer assigned to the Automation Solution. (7.4.1.3.-4)						
VCSC.12-07	G. It should provide functions to configure password policies to achieve a minimum complexity commonly accepted by both the security and industrial automation communities. (7.4.1.3.-5)	□Not Applicable □Checked □Not Compliant					
VCSC.12-08	H. It should provide functions to configure passwords for local and system-wide user accounts to automatically expire after they have been in use for a period of time specified by the PE/O. (7.4.1.3.-6 (SP.09.06 BR))	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
VCSC.12-09	I. The password policies should provide functions to prompt users to change passwords N days before they expire, where N is specified by the PE/O. It should notify them that their passwords are expiring so they have time to change them. (7.4.1.3.-6. (1). (SP.09.06 RE (1)))	□Not Applicable □Checked □Not Compliant					
VCSC.12-10	J. Default passwords should be changed as required by the PE/O, including after the process of installation, re-installation, and reset/recovery. (7.4.1.3.-7)	□Not Applicable □Checked □Not Compliant					
VCSC.12-11	K. It should provide functions for password policies to prevent users from reusing their last N passwords, where N is specified by the PE/O.	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	(7.4.1.3.-8 (SP.09.08 BR))						
VCSC.12-12	L. A secure document shall be created and keep this documentation current for accounts whose passwords have been approved by the PE/O to be shared with the Project. (7.4.1.3.-9)	□Not Applicable □Checked □Not Compliant					
VCSC.12-13	M. It shall report to the PE/O passwords that were: a. shared and no longer need to be shared, b. knowingly divulged, or c. knowingly compromised, and support the PE/O in changing passwords as necessary. (7.4.1.3.-9. (1))	□Not Applicable □Checked □Not Compliant					
VCSC.12-14	N. It should provide functions for password policies to prevent users from changing their passwords more	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	frequently than once every N days, where N is specified by the PE/O. (7.4.1.3.-8(1) (SP.09.08 RE(1)))						
Security Patching							
VCSC.13	(1) Patch Management Description						
VCSC.13-01	A. A document should be provided to the PE/O that describes how security patches for Automation Solution software for which it is responsible are evaluated and approved. (7.4.1.11-2)	□Not Applicable □Checked □Not Compliant					
VCSC.13-02	B. The patch management process document shall include the process to inform PE/O about the description of security patches/updates. (7.4.1.11-3)	□Not Applicable □Checked □Not Compliant					
VCSC.13-03	C. If it is not permitted to install a security patch that could negatively	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	impact the Automation Solution, it should: a. recommend a mitigation plan when requested by the PE/O for security patches that were applicable and approved by the Project, but that were not approved by the PE/O, for example, because they could impact operations or performance (see SP 11.05 BR), b. implement the mitigation plan after approval by the PE/O. (7.4.1.11-3. (2))						
VCSC.13-04	D. The management of patches should provide for: a. patches to be obtained by the PE/O directly from the manufacturer of the patch, and/or	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	b. redistribution of patches by the Project only if approved by the PE/O and permitted by the manufacturer of the patch. It should ensure that patches are obtained through an authorized channel (from an appropriate source) to reduce the possibility that they could be invalid/infected. (7.4.1.11-4)						
VCSC.13-05	E. The patch management documentation should include a description of how to perform patching both manually and via a patch management server and how to obtain patching status reports. (7.4.1.11-5)	□Not Applicable □Checked □Not Compliant					
VCSC.13-06	F. The patch management process document shall	□Not Applicable □Checked					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	include and ensure that, if the PE/O requests the Project to install security software patches, the Project should install them at a time specified by the PE/O. The patch should be installed only when the PE/O wants it to be installed. (7.4.1.11-7)	□Not Compliant					
VCSC.13-07	G. It should ensure that the security hardening level of the Automation Solution is retained after patch installation. It should ensure that patch installation does not "undo" or otherwise degrade the hardening of the Automation Solution. The patch management process document shall include a process for restoring the hardening	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	state of the Automation Solution if patch installation causes it to degrade. After the patch, it should perform a vulnerability testing or hardening inspection to detect the degraded condition, and determine if this has happened, and if it has to restore the hardening. (7.4.1.11-7.(1))						
VCSC.13-08	H. The patch list document should include and determine the installation status of all security patches applicable to the Automation Solution for which the Project is responsible. (7.4.1.11-7.(3))	□Not Applicable □Checked □Not Compliant					
VCSC.14	(2) Patch Evaluation Description						
VCSC.14-01	A. A document should be provided to the PE/O that	□Not Applicable □Checked					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	describes how security patches for Automation Solution software for which it is responsible are evaluated and approved. (7.4.1.11-2)	□Not Compliant					
VCSC.14-02	B. The patch management process document shall include a process for the PE/O to review, as a result of changes in security risks, how it evaluates and approves security patches for Automation Solution software for which it is responsible. The patch process should include the patch evaluation process in response to changes in the cyber-security threat landscape. (7.4.1.11-2. (1))	□Not Applicable □Checked □Not Compliant					
Backup and Restore							
VCSC.15	(1) Backup Schedules Configuration Description						

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
VCSC.15-01	A. A document should be provided for recommended backup procedures for the Automation Solution. (7.4.1.12.-1)	□Not Applicable □Checked □Not Compliant					
VCSC.15-02	B. It should provide documented instructions to the PE/O for restoring the Automation Solution or its components to normal operation. (7.4.1.12.-2)	□Not Applicable □Checked □Not Compliant					
VCSC.15-03	C. It should provide documentation to the PE/O that describes how to control and securely manage portable backup media. (7.4.1.12.-3)	□Not Applicable □Checked □Not Compliant					
VCSC.15-04	D. It should provide documentation to the PE/O that describes how to verify successful system backup.	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	(7.4.1.12.-4)						
VCSC.15-05	E. It should provide documentation to the PE/O that describes how to demonstrate that: a. it is possible to perform a complete backup of the Automation Solution, and b. it is possible to restore a fully functioning Automation Solution from this backup. (7.4.1.12.-5)	□Not Applicable □Checked □Not Compliant					
VCSC.15-06	F. It should have procedures to perform a backup of the Automation Solution in accordance with the PE/O's backup schedules and data restoration and disaster recovery objectives. (7.4.1.12.-6)	□Not Applicable □Checked □Not Compliant					
VCSC.15-07	G. It should test and demonstrate that the Automation Solution is	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	able to continue normal operation during a backup. (7.4.1.12.-7)						
VCSC.15-08	H. It should provide documentation to the PE/O that describes how to generate and maintain audit logs of all backups and restore activities. (7.4.1.12.-8)	□Not Applicable □Checked □Not Compliant					
VCSC.15-09	I. A recommended disaster recovery plan document should be provided, and includes, but is not limited to, the following: a. a description of various disaster scenarios and their impact on the Automation Solution, b. step-by-step instructions for restoring, restarting failed components, and integrating them into the Automation Solution,	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	c. minimum architecture requirement for restoring the entire Automation Solution. (7.4.1.12.-9)						
VCSC.16	(2) Recovery Testing Mechanisms Description relates to provide documentation to the PE/O that describes how to demonstrate that: a. it is possible to perform a complete backup of the Automation Solution, and b. it is possible to restore a fully functioning Automation Solution from this backup. (7.4.1.12.-5)	□Not Applicable □Checked □Not Compliant	□	□			
Remote Interactive Access							
VCSC.17	(1) Session Logging – Event Management Description						
VCSC.17-01	A. An audit log shall be configured to write and collect all security-related events, including user	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	activities and account management activities, and shall be kept for the number of days specified by the PE/O or Security Policies and Procedures Management Plan. (7.4.1.9.-3)						
VCSC.17-02	B. The security-related data and events should be accessed through one or more interfaces that is/are commonly accepted by both the security and industrial automation communities. (7.4.1.9.-3(1))						
VCSC.17-03	C. It shall verify that security-related events can be written to an audit log. Audit logs require a higher level of integrity protection than provided by typical event logs. (7.4.1.9.-3. (2))	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
VCSC.17-04	D. To log and notify the operator of process-related events as required by the PE/O shall be configured. (7.4.1.9.-4)	□Not Applicable □Checked □Not Compliant					
VCSC.17-05	E. The report alarms/alerts/events through an interface shall be secure that is commonly accepted by both the security and industrial automation communities. (7.4.1.9.-4. (1))	□Not Applicable □Checked □Not Compliant					
VCSC.17-06	F. A document should be provided to the PE/O that describes the Automation Solution's ability to withstand the near-simultaneous occurrence of large numbers of events, typically referred to as event storms. (7.4.1.9.-5)	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
VCSC.18	(2) Default Credentials Removed Description						
VCSC.18-01	A. The account management shall provide to create and maintain unique accounts for each Automation Solution user. It should prevent users from having to share accounts, i.e. by having a separate account. (7.4.1.3.-2)	□Not Applicable □Checked □Not Compliant					
VCSC.18-02	B. An account management document should be provided to the PE/O that: a. identifies all default user and service accounts that are installed in the Automation Solution, b. describes the tools and procedures the PE/O can use to set/reset passwords for all default user and service accounts. (7.4.1.3.-2. (1))	□Not Applicable □Checked □Not Compliant					
VCSC.18-03	C. The built-in administrator account should be	□Not Applicable □Checked					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	disabled, and if that is not possible, that it should be renamed or otherwise made difficult to exploit. (7.4.1.3.-2. (4))	□Not Compliant					
VCSC.19	(3) Multifactor Authentication Description relates to remote access connections conducted over the Internet or over other publicly accessible media that are used to support remote access to the Automation Solution by the Project shall be protected, such as authentication and encryption, as required by the PE/O.	□Not Applicable □Checked □Not Compliant	□	□			
Network Security							
VCSC.20	(1) Network Segmentation Description relates to identify and document the network segments of the SuC and their interfaces to other segments and for each interface designate whether it is trusted or untrusted.	□Not Applicable □Checked □Not Compliant	□	□			

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	(7.3.1.1-4. (1))						
VCSC.21	(2) Zoning and Conduits Description relates to assess the interfaces of the SuC that have been identified as untrusted and are protected by network security devices or equivalent mechanisms, with documented and maintained security rules. (7.3.1.1-4. (2))	□Not Applicable □Checked □Not Compliant	□	□			
VCSC.22	(3) Documentation and Schematics Description						
VCSC.22-01	A. During the implementation of network architecture, all network interfaces should be maintained and updated to the latest. (7.4.1.4-2. (1))	□Not Applicable □Checked □Not Compliant					
VCSC.22-02	B. During the implementation of network architecture, an Inventory Asset List should be maintained and updated to the latest. (7.4.1.4-2. (2))	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
VCSC.22-03	C. The network architecture documentation should keep its documentation up-to-date and describe the devices connected to each network segment in the Automation Solution. (7.4.1.4-2. (3))	□Not Applicable □Checked □Not Compliant					
VCSC.23	(4) Logging and Auditing Controls – Event Management Description						
VCSC.23-01	A. An audit log shall be configured to write and collect all security-related events, including user activities and account management activities, and shall be kept for the number of days specified by the PE/O or Security Policies and Procedures Management Plan. (7.4.1.9.-3)	□Not Applicable □Checked □Not Compliant					
VCSC.23-02	B. To log and notify the operator of process-related events as required	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	by the PE/O shall be configured. (7.4.1.9.-4)						
VCSC.23-03	C. The report alarms/alerts/events through an interface shall be secure that is commonly accepted by both the security and industrial automation communities. (7.4.1.9.-4. (1))	□Not Applicable □Checked □Not Compliant					
Logging and Auditing – Event Management							
VCSC.24	(1) Auditable Events Identification Description						
VCSC.24-01	A. An audit log shall be configured to write and collect all security-related events, including user activities and account management activities, and shall be kept for the number of days specified by the PE/O or Security Policies and Procedures Management Plan.	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	(7.4.1.9.-3)						
VCSC.24-02	B. It shall verify that security-related events can be written to an audit log. Audit logs require a higher level of integrity protection than provided by typical event logs. (7.4.1.9.-3. (2))	□Not Applicable □Checked □Not Compliant					
VCSC.24-03	C. To log and notify the operator of process-related events as required by the PE/O shall be configured. (7.4.1.9.-4)	□Not Applicable □Checked □Not Compliant					
VCSC.24-04	D. The report alarms/alerts/events through an interface shall be secure that is commonly accepted by both the security and industrial automation communities. (7.4.1.9.-4. (1))	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
VCSC.24-05	E. A document should be provided to the PE/O that describes the Automation Solution's ability to withstand the near-simultaneous occurrence of large numbers of events, typically referred to as event storms. (7.4.1.9.-5)	□Not Applicable □Checked □Not Compliant					
VCSC.24-06	F. session locking function for SuC's workstations as required by the PE/O. This requirement applies only to the workstations for which the Project is responsible. The Session locking should: i. prevent information on the logged-on user's display device from being viewed, and ii. block input from the user's input device (e.g. keyboard, mouse) until	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	unlocked by the session user or an administrator. (7.4.1.2.-5)						
VCSC.25	(2) User Logging Configuration Description						
VCSC.25-01	A. An audit log shall be configured to write and collect all security-related events, including user activities and account management activities, and shall be kept for the number of days specified by the PE/O or Security Policies and Procedures Management Plan. (7.4.1.9.-3)	□Not Applicable □Checked □Not Compliant					
VCSC.25-02	B. It shall verify that security-related events can be written to an audit log. Audit logs require a higher level of integrity protection than provided by typical event logs. (7.4.1.9.-3. (2))	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
VCSC.25-03	C. To log and notify the operator of process-related events as required by the PE/O shall be configured. (7.4.1.9.-4)	□Not Applicable □Checked □Not Compliant					
VCSC.25-04	D. The report alarms/alerts/events through an interface shall be secure that is commonly accepted by both the security and industrial automation communities. (7.4.1.9.-4. (1))	□Not Applicable □Checked □Not Compliant					
VCSC.25-05	E. A document should be provided to the PE/O that describes the Automation Solution's ability to withstand the near-simultaneous occurrence of large numbers of events, typically referred to as event storms. (7.4.1.9.-5)	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
VCSC.26	(3) Device Logging Configuration Description						
VCSC.26-01	A. An audit log shall be configured to write and collect all security-related events, including user activities and account management activities, and shall be kept for the number of days specified by the PE/O or Security Policies and Procedures Management Plan. (7.4.1.9.-3)	□Not Applicable □Checked □Not Compliant					
VCSC.26-02	B. It shall verify that security-related events can be written to an audit log. Audit logs require a higher level of integrity protection than provided by typical event logs. (7.4.1.9.-3. (2))	□Not Applicable □Checked □Not Compliant					
VCSC.26-03	C. To log and notify the operator of process-related events as required	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	by the PE/O shall be configured. (7.4.1.9.-4)						
VCSC.26-04	D. The report alarms/alerts/events through an interface shall be secure that is commonly accepted by both the security and industrial automation communities. (7.4.1.9.-4. (1))	□Not Applicable □Checked □Not Compliant					
VCSC.26-05	E. A document should be provided to the PE/O that describes the Automation Solution's ability to withstand the near-simultaneous occurrence of large numbers of events, typically referred to as event storms. (7.4.1.9.-5)	□Not Applicable □Checked □Not Compliant					
VCSC.27	(4) Network Logging Configuration Description						
VCSC.27-01	A. An audit log shall be configured to write and	□Not Applicable □Checked					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	collect all security-related events, including user activities and account management activities, and shall be kept for the number of days specified by the PE/O or Security Policies and Procedures Management Plan. (7.4.1.9.-3)	□Not Compliant					
VCSC.27-02	B. It shall verify that security-related events can be written to an audit log. Audit logs require a higher level of integrity protection than provided by typical event logs. (7.4.1.9.-3. (2))	□Not Applicable □Checked □Not Compliant					
VCSC.27-03	C. To log and notify the operator of process-related events as required by the PE/O shall be configured. (7.4.1.9.-4)	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
VCSC.27-04	D. The report alarms/alerts/events through an interface shall be secure that is commonly accepted by both the security and industrial automation communities. (7.4.1.9.-4. (1))	□Not Applicable □Checked □Not Compliant					
VCSC.27-05	E. A document should be provided to the PE/O that describes the Automation Solution's ability to withstand the near-simultaneous occurrence of large numbers of events, typically referred to as event storms. (7.4.1.9.-5)	□Not Applicable □Checked □Not Compliant					
VCSC.28	(5) Security Tools Logging – Malware Protection Description relates to commonly accepted interfaces (7.4.1.9.-3. (1)) which related	□Not Applicable □Checked □Not Compliant	□	□			

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	to Security Tools Logging for Malware Protection.						
VCSC.29	(6) Threat Detection Description						
VCSC.29-01	A. Ensure that devices with detectable infections are not installed in the Automation Solution (7.4.1.10.-5)	□Not Applicable □Checked □Not Compliant					
VCSC.29-02	B. For portable media that is used for system testing, commissioning, and/or maintenance, it should be used this portable media for this purpose only. (7.4.1.10.-5. (1))	□Not Applicable □Checked □Not Compliant					
VCSC.29-03	C. All portable media used in or connected to the Automation Solution by the Project should be free of known malware before use in the Automation Solution. (7.4.1.10.-5. (2))	□Not Applicable □Checked □Not Compliant					
VCSC.30	(7) Intrusion Detection and Protection Configuration	□Not Applicable □Checked	□	□			

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	Description relates to malware protection mechanisms which related to intrusion Detection and Protection Configuration or Malware Protection.	□Not Compliant					
Safety Instrumented System (SIS)							
VCSC.31	(1) Safety Instrumented System (SIS) security (if applicable) Description						
VCSC.31-01	A. The SIS communications critical to safety functions shall not be affected by other communications of the Automation Solution. It should have the physical separation of BPCS communications and the SIS. (7.4.1.7.-1)	□Not Applicable □Checked □Not Compliant					
VCSC.31-02	B. The external communications to the Automation Solution, including remote access communications, shall not be able to interfere with the operation of the SIS. (7.4.1.7.-2)	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
VCSC.31-03	C. The applications external to the SIS shall not be able to participate in disrupt or otherwise interfere with SIS communications that are critical to safety functions. (7.4.1.7.-3)	□Not Applicable □Checked □Not Compliant					
VCSC.31-04	D. The SIS EWSs that reside outside the SIS should be protected from compromise by communications from Level 3 or above. Access from Level 3 applications to SIS engineering workstations that reside within the SIS is prohibited. (7.4.1.7.-4)	□Not Applicable □Checked □Not Compliant					
VCSC.31-05	E. The SIS engineering workstations within the SIS (1a) either should not have remote access	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	installed or (1b) should be disabled (not accessible), and/or (2) have security mechanisms that block remote access communications with these workstations. (7.4.1.7.-5)						
VCSC.31-06	F. All access to the Automation Solution's SIS from outside the SIS shall be mediated and authorized at the interface to the SIS. Access controls to the SIS should be implemented at the interface to the SIS. (7.4.1.7.-6)	□Not Applicable □Checked □Not Compliant					
VCSC.31-07	G. The SIS functions performed by the Automation Solution's SIS EWSs shall be protected from compromise by other SIS EWS software. It should	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	reduce the possibility that the SIS EWS will contain T3 offline software (see IEC 61508-3) that could intentionally or inadvertently cause harm to the SIS. (7.4.1.7.-7)						
VCSC.31-08	H. Unauthorized wireless devices shall not be used as an integral part of SIS safety functions, to prevent attacks against the SIS by unauthorized wireless devices. (7.4.1.7.-8)	□Not Applicable □Checked □Not Compliant					
VCSC.31-09	I. It shall provide a function process and/or procedure document to enable and disable a hardware implementation of the configuration mode interface required by SP.05.09 BR and to physically lock this	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	hardware implementation while the configuration mode is disabled. (7.4.1.7.-9. (1))						
VCSC.31-10	J. It shall provide a function process and/or procedure document that can be performed for an independent third-party to verify that it is not possible to change the configuration of the SIS when the hardware interface described in SP.05.09 RE (1) is locked in the "disable" configuration mode. (7.4.1.7.-9. (2))	□Not Applicable □Checked □Not Compliant					
Wireless Security							
VCSC.32	(1) Wireless Security (if applicable) Description						
VCSC.32-01	A. Implement the following functions of the wireless systems: a. data exchange to/from wireless instrumentation,	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	b. data exchange through a secure wireless link, c. security mechanisms that prevent an intruder from gaining access to the Automation Solution using the wireless system, d. security mechanisms that restrict access within the Automation Solution by workers with handheld wireless devices, e. where required, security mechanisms that protect for remote management of wireless systems. (7.4.1.6.-1)						
VCSC.32-02	B. The protection of wireless access shall be configured to use wireless authentication and access control mechanisms that are commonly accepted by both the security and	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	industrial automation communities. (7.4.1.6.-2)						
VCSC.32-03	C. The protection of wireless access shall be configured to protect wireless communications, and if cryptographic mechanisms are used for this purpose, they are commonly accepted by both the security and industrial automation communities. (7.4.1.6.-3)	□Not Applicable □Checked □Not Compliant					
VCSC.32-04	D. The wireless protocols used in the SuC should use commonly accepted standard wireless technology. (7.4.1.6.-4)	□Not Applicable □Checked □Not Compliant					
VCSC.32-05	E. The identifiers of the wireless network should not allow an external listener to identify the	□Not Applicable □Checked □Not Compliant					

Documents of System Security Countermeasures Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	physical wireless network, its location, or the owner of the wireless network. (7.4.1.6.-5)						
VCSC.32-06	F. The wireless networks are configured to prevent: a. the use of unauthorized device addresses, and b. interference with the assignment of device addresses. (7.4.1.6.-6)	□Not Applicable □Checked □Not Compliant					

C.7 System Security Acceptance Testing Verification Checklist

To verify the System Security Acceptance Testing Verification Documents.

Table C.7 System Security Acceptance Testing Verification Checklist.

System Security Acceptance Testing Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
VCAT.01	OT Security FAT Test: use security analysis tools to discover undocumented and/or unauthorized systems or vulnerabilities in the assets.	□Not Applicable □Checked □Not Compliant	□	□			
VCAT.02	OT Security FAT Test: use security analysis tools to discover hidden devices, undocumented open TCP/UDP ports,	□Not Applicable □Checked □Not Compliant	□	□			
VCAT.03	OT Security FAT Test: check the vulnerability management process (7.1.4.4 2.) to mitigate security weaknesses	□Not Applicable □Checked □Not Compliant	□	□			
VCAT.04	OT Security FAT Test: check the security hardening guidelines and procedures are followed.	□Not Applicable □Checked □Not Compliant	□	□			
VCAT.05	OT Security FAT Test: Check and inspect the measures or countermeasures implemented to mitigate the threat and test the resilience of these implemented measures or countermeasures. It is tested	□Not Applicable □Checked □Not Compliant	□	□			

System Security Acceptance Testing Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	and/or inspected, and the function descriptions are documented						
VCAT.06	The Security Policies and Procedures and/or Security Functional Description Specification, and function test records are inspected and reviewed.	□Not Applicable □Checked □Not Compliant	□	□			
VCAT.07	OT Security SAT Test: use security analysis tools to discover undocumented and/or unauthorized systems or vulnerabilities in the assets.	□Not Applicable □Checked □Not Compliant	□	□			
VCAT.08	OT Security SAT Test: use security analysis tools to discover hidden devices, undocumented open TCP/UDP ports,	□Not Applicable □Checked □Not Compliant	□	□			
VCAT.09	OT Security SAT Test: check the vulnerability management process (7.1.4.4 2.) to mitigate security weaknesses	□Not Applicable □Checked □Not Compliant	□	□			
VCAT.10	OT Security SAT Test: check the security hardening	□Not Applicable □Checked	□	□			

System Security Acceptance Testing Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
	guidelines and procedures are followed.	□Not Compliant					
VCAT.11	OT Security SAT Test: check if approved network segmentation is implemented and verified according to the approved network and data flow diagram designed.	□Not Applicable □Checked □Not Compliant	□	□			
VCAT.12	OT Security SAT Test: Threat Mitigation Test is performed	□Not Applicable □Checked □Not Compliant	□	□			
VCAT.13	OT Security SAT Test: Penetration Testing is performed	□Not Applicable □Checked □Not Compliant	□	□			
VCAT.14	OT Security SAT Test: Verify and check the Policies and Procedures Integration and Hardening settings which comply with IEC 62443-2-4 requirements.	□Not Applicable □Checked □Not Compliant	□	□			

C.8 Operation and Support/Maintenance Verification Checklist

To verify the Operation and Support/Maintenance documents.

Table C.8 Operation and Support/Maintenance Verification Checklist.

Operation and Support/Maintenance Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
VCOM.01	Check if use security analysis tools to discover undocumented and/or unauthorized systems or vulnerabilities in the assets.	□Not Applicable □Checked □Not Compliant	□	□			
VCOM.02	Check if use security analysis tools to discover hidden devices, undocumented open TCP/UDP ports,	□Not Applicable □Checked □Not Compliant	□	□			
VCOM.03	Check if the vulnerability management process (7.1.4.4 2.) to mitigate security weaknesses	□Not Applicable □Checked □Not Compliant	□	□			
VCOM.04	Review the tasks and reports of the security review	□Not Applicable □Checked □Not Compliant	□	□			
VCOM.05	Review the tasks and reports of the type/setting/configuration management.	□Not Applicable □Checked □Not Compliant	□	□			
VCOM.06	Review the tasks and reports of the Management of Change (MOC)	□Not Applicable □Checked □Not Compliant	□	□			

Operation and Support/Maintenance Verification Checklist							
Dept.					Date		
Project					Inspector		
Serial No.							
No.	Item	Requirement	Observations		Compliance statement	Evidence Lists	Remarks / Recommendations /Corrective Actions
			Pass	Fail			
VCOM.07	Review the tasks and reports of the Regular security testing and/or evaluation	□Not Applicable □Checked □Not Compliant	□	□			
VCOM.08	Review the tasks and reports of the SuC's cybersecurity incident response and recovery	□Not Applicable □Checked □Not Compliant	□	□			
VCOM.09	Review the tasks and reports of the continuous monitoring	□Not Applicable □Checked □Not Compliant	□	□			

--- End of Document ---